System Design: the Northstar demo of the Forma company app platform

Two apps in one platform build, Northstar's outbound investigation and Spend Review, as one team's reduced deployment of the platform designed in `tasks/forma-generative-app-platform-v2/`; the demo recorded for YC.

Author	Victor Villacis
Date	2026-10-22
Status	Proposed
Revises	Design B v5 (`task/forma-mvp/v5`, the earlier demo record) in direction: the demo inside the platform, now two apps on the typed app definition instead of the insurance demo on markup modules; none of v5's scenes, fixtures or modules carries over
Reviewers	A fresh reviewer and the security reviewer at phase 7 (L2); recorded in STATUS.md
Approvers	Victor Villacis (the head)
Review by	2026-11-05
Read first	`input/brief.md`; `PRODUCT-BRIEF.md` (the controlling definition, the six acts); `SCENARIOS.md`; `BUILD-HANDOFF.md`; the platform record `tasks/forma-generative-app-platform-v2/design.md` and its reading note

Contents

1. Summary
2. Context and problem statement
3. Goals, non-goals, and assumptions
    - 3.1 Goals
    - 3.2 Non-goals
    - 3.3 Assumptions
4. Requirements
    - 4.1 Functional
    - 4.2 Quality requirements (non-functional)
5. Architecture overview
    - 5.1 System context
    - 5.2 Containers
    - 5.3 Key decisions
6. Component design
    - 6.1 Workspace server (P2, role `workspace`)
    - 6.2 Control plane (P3, role `control`)
    - 6.3 Data service (P4, role `data`)
    - 6.4 Workers and the parser sandbox (P5, P6, P7, role `worker`)
    - 6.5 Browser workspace (P8)
    - 6.6 The stores and the host's edge (DS1, DS2, DS3, P1)
    - 6.7 Demo-only components
    - 6.8 Reductions and seams
    - 6.9 Dependencies
7. Data flows
    - 7.1 Acts 1 to 5: the platform's flows 1 and 2, with receipts kept
    - 7.2 Act 6: the record command, the return to Security and the evidence
    - 7.3 The operator's flows
8. Data model and storage
9. API surface
10. Security and threat model
    - 10.1 Scope and assumptions
    - 10.2 Trust boundaries, trust levels, and assets
    - 10.3 Threat actors and attack goals
    - 10.4 STRIDE analysis
    - 10.5 Authentication and authorization
    - 10.6 Secrets and data protection
    - 10.7 Accepted risks and validation
11. Operations
    - 11.1 Deployment view, rollout, and migration
    - 11.2 Scaling and cost
    - 11.3 Observability
    - 11.4 Failure modes and recovery
12. Alternatives considered
    - 12.1 Drawbacks of the chosen design
    - 12.2 Alternatives
    - 12.3 Abandoned ideas
13. Risks, open questions, objections, and future work
    - 13.1 Risks
    - 13.2 Open questions
    - 13.3 Objections

Appendix

- A. Glossary
- B. References
- C. Threat rows beyond section 10.4

> **How to read this record.** "§N" is section N of the controlling definition, the App Platform definition in `input/context/`, which `PRODUCT-BRIEF.md` in this folder restates for the demo, `SCENARIOS.md` turns into the fixtures **S01 to S07** and `BUILD-HANDOFF.md` into eight reductions with their seams; this record's own sections are cited as plain numbers. "The platform record" is `tasks/forma-generative-app-platform-v2/design.md`, the design this demo reduces; it revises design A (`task/forma-platform/v4`, the security-first platform on markup modules), as this record revises design B (`task/forma-mvp/v5`, design A's insurance demo). Identifier families: **K1 to K5** are the head's kickoff rulings of 2026-10-22, recorded in both tasks' `intake.md`: K1 the typed app definition rendered by first-party components, K2 standard mode at L2, K3 the stack tickets assumed done, K4 fAuth first, its build checked viable and its sign-in moment ruled in on 2026-10-22 as a quiet real moment with no passkey button, K5 Parquet and DuckDB for sources with PostgreSQL for records. **C01 to C16** are the shared contracts (`SHARED-CONTRACTS.md`, lock edition `prep-2026-10-22.1`). A bare **D**, **G**, **A**, **R**, **N**, **F**, **SA**, **AG**, **TH**, **M**, **AR**, **RK** or **SR** number is this record's, and **TL**, **SI**, **AS** and **TA** continue the platform's numbering; the platform's are always prefixed "platform", and platform D15, hosting on AWS in one region, is the one platform decision this record reduces rather than binds (D10). **A1 to A10** come from the intake, A11 to A14 from the K rulings and the fAuth check (`review/fauth-viability.md`). **EXP-002** is S05's fixture expense, 45,000 cents; `ik-1` and `ik-2` are the packet's names for the idempotency keys of its two record commands, `ik-3` the stale edit's. The *28,100 B budget* is Forma's gzip ceiling for one route's Forma payload (BUILD-819), the figure the canvas route is measured against. Status tags: **[built]** exists at a named pin; **[proposed]** is this design; **[reduced: the platform's X]** replaces the platform's X here, with the seam in section 12; a tag may name the part it covers, as in [built: the rendering]. Terms, in the platform's sense: a *space* is a company-defined area of apps inside an organization, Security and Finance here; the *canvas* is the surface on which an app's views are arranged, rendered by one browser *island*; the *composer* is the assistant that turns an intent into a proposed definition or patch, through a job the worker runs; the *control plane* admits definitions and alone writes publications and policy, and its *admission report* says what it checked and refused; the *data service* runs typed queries and record commands; a *receipt* is the server's record of exactly which sources, revisions, parameters and policy produced a number; a *case* is saved work, one id *pinned* to the publication it was started on with its bindings, records and notes, moved to a newer publication only by explicit *adoption*; an *expected version* is the record version a command was based on, so a stale command conflicts; an *epoch* is a counter that a change of filter, membership or policy advances, so a late result can be told from a current one; the *canary* is the second synthetic organization whose scripted suite replays every call with Northstar's identifiers and must be denied; the *packet* is the evidence bundle delivered with the recording (S07); the *platform key* is fAuth's credential for creating tenants, held only by the operator's script.

1. Summary

The Northstar demo is the platform record's design as one process on one host, recorded in six acts: Maya forms an investigation app over imported evidence, Sarah publishes it, Jordan reuses her work, and Maya forms Spend Review, a different app, by the same path, no deploy between (section 5). A recording of two fixed dashboards would prove none of it (section 2), so the design keeps the platform's code, reduces its deployment eight ways with named seams (6.8), adds three operator tools, the reset under a rehearsal flag (6.7), and signs in through fAuth as a registered client (D9). It optimises for generality and isolation, one build digest across six acts and nothing of Northstar reaching the canary, at the expense of scale, availability, generation latency and cost: one host, no standby, a restart that is a scene. It covers the six acts, the spike, the rehearsal procedure and the packet; a pilot on real data, a production SLO and the passkey button are out (3.2). One-way doors: the organization id in every key (D2), the platform's definition and command code (D3), the integrity rule once the packet is submitted (D7); the rest of 5.3 reverses.

2. Context and problem statement

This record designs the platform's demo: two apps formed, published and reused on one reduced build, recorded for YC against its request A Cloud for Small Software, which asks that small software be as easy to share with colleagues as a Google Doc (§20). The platform forms governed apps over imported data: a model proposes a typed definition, a reviewer publishes it, every number carries a receipt. Market framing and the prototypes' limits: platform section 2.

What the demo must establish. The controlling definition has six acts (§16): enter the workspace, bring data, form and transform an app, publish and run it, share and reuse it, build a different app. The last "must show a meaningful difference in purpose and behavior, not merely two fixed dashboards behind different colors" (§16). The completeness test (§18) asks that "at least two apps with different purposes or interactions" exercise one creation, publication, access and saved-work model, that a second user works independently, saved work reopens with its context, revocation holds, and a published app survives a failing draft. S01 to S07 (`SCENARIOS.md`) are those clauses as fixtures.

What exists. The platform record (`tasks/forma-generative-app-platform-v2/design.md`) at its phase 7 gate commit `0de0308`: contracts C01 to C16 at lock edition `prep-2026-10-22.1`, decisions D1 to D15, binding except D15, which D10 reduces. The native composition fixture (platform review 4.3), which compiled a canvas of four component kinds on Forma 3.0.0 `2006423b` with data at first paint, at 27,674 B of the route's 28,100 B gzip budget. fAuth, Forma's own identity service (`getforma-dev/gatewasm`), at `b750ca53`: 44 smoke tests pass, the `northstar` tenant is provisioned (`review/fauth-viability.md`).

What a recording of two fixed dashboards would fail to prove. The fixtures are S02's five connection events, 1,140,000 bytes in a ten-minute window, and S05's expense EXP-002, whose decision moves from `needs_context` to `reviewed`. Take the shortest path to pixels:

1. A developer writes a handler that sums S02's bytes and divides by ten minutes. The number is right, but the denominator lives in code; act 3's "meaningful change" is a commit the recording cannot attribute. Act 6 fails §18 outright: Spend Review is a second handler.
2. The decision form on EXP-002 keeps `needs_context` in browser state. S05's 64,000-cent table and 45,000-cent queue display correctly; a reload loses the decision, a retried submit makes two, and nothing holds an expected version (platform R8).
3. One session plays Maya, Sarah and Jordan. No publish is refused, no shared work reopens under another principal, no canary organization is denied; §18's isolation and reuse clauses go untested.

Each shortcut is invisible in a video; the record, not the recording, carries the evidence (S07).

Constraints. Technical: one process on one host (platform D11); synthetic data; the typed app definition (K1; platform D1); the native composition fixture as the spike's first step; the eight reductions of `BUILD-HANDOFF.md`, each naming the platform seam that replaces it (section 6's table); Forma's compiler limits unchanged (platform section 2). Organisational: the spike precedes any rehearsed scene; one founder builds and operates; fAuth's sign-in moment is ruled in, quiet (K4). Conventions: Northstar is fictional; simulated behavior is labeled and "excluded from working-capability acceptance" (`PRODUCT-BRIEF.md`); a login dropdown, work only in browser memory, faked commits or a hardcoded act 6 are not reductions.

Scale regime. A rehearsal, not a service: two organizations, five accounts including the operator, at most four concurrent sessions, about 0.8 actions/s sustained (A4). The platform's envelope is its section 4.

3. Goals, non-goals, and assumptions

3.1 Goals

The design goals are **six acts on one build** (one image digest, no deploy between acts), **generality** (one typed definition path, no branch on a name), **governed persistence** (records in one transaction under expected versions and idempotency keys), **isolation** (the organization id in every key, row-level security, two data keys), **integrity** (every scene names its mechanism, the packet carries the evidence) and **a path to the platform** (every reduction names its seam), checked on the running demo.

- **G1 Six acts, one build.** Done when acts 1 to 6 (§16) run end to end on one build digest on which S01 to S07 pass and the seven completeness clauses (§18) are ticked.
- **G2 Two apps, one authoring path.** Done when act 6 creates Spend Review through act 3's interface with no commit or deploy between, and the runtime has no branch on `Northstar`, `Security` or `Finance` (platform G1, R14; S07).
- **G3 Work continues and reuses.** Done when Jordan reopens Maya's case by its work id at its pinned publication with its records, a concurrent edit conflicts visibly, and his work for `ops-runner-04` totals 210,000 bytes under its own id while Maya's 1,140,000 stand (S04).
- **G4 Records persist, retry safely, conflict visibly.** Done when EXP-002's decision survives refresh and restart, an `ik-1` retry yields one revision and one audit event, a stale version conflicts, and `ik-2` makes version 2 (S05; platform G4, D5).
- **G5 Isolation shown with the canary.** Done when the canary organization replays every call and link with Northstar's identifiers and gets nothing, not even metadata; a Security-only principal cannot read Finance; revocation stops derived and queued results (S01, S06; platform G5).
- **G6 Nothing simulated passes as working.** Done when every scene names its mechanism, every seeded, simulated or manual step is labeled and excluded from S07's acceptance measures, and the packet holds pins, digests, receipts, record outcomes and the rehearsal log (S07).
- **G7 The demo grows into the platform.** Done when each reduction names its seam (section 12) and every container maps onto a platform container under D1 to D14 (platform C16).

Success: six acts on one build, Spend Review made without a developer, every section 4 target met. Failure (intake item 35): two fixed dashboards, a per-example platform change, lost work, unsafe reuse, a security tool posing as the platform.

3.2 Non-goals

Platform 3.2's non-goals hold here. The demo adds:

- **Customer data or a pilot.** Synthetic rows prove mechanisms, not adoption (§19).
- **A production SLO.** One host and one operator cannot promise one (platform N2); we measure.
- **fAuth's passkey button.** Server-ready, unwired at `b750ca53`; ruled out (K4): sign-in is ten quiet seconds.
- **An MCP scene and a public page.** Design B v5 had both; K1 needs neither, §18 defers both.
- **Coediting.** Act 6 shows a conflict, not a cursor; expected versions are the seam.

3.3 Assumptions

Envelopes, not forecasts (provenance: the reading note).

- **A1 Audience.** A YC partner watching, an engineer reading. If wrong: the editions.
- **A2 Roles.** Maya builds, Sarah reviews, Jordan reuses, under explicit grants. If wrong: grants move, authority holds.

- **A3 One operator** provisions, resets and restores. If wrong: section 11 names more.
- **A4 Scale and rate.** Two organizations, five accounts, four sessions, 0.8 actions/s sustained, four-action bursts. If wrong: remeasure.
- **A5 Read-heavy**, writes measured in rehearsal. If wrong: load-test commits.
- **A6 Input caps.** CSV 10 MiB, 100,000 rows; XLSX 5 MiB compressed, 50 MiB expanded, 10,000 rows × 32 columns per sheet: a tenth of the platform's A4 for CSV and half for XLSX, a reduction (6.4) still far above the fixtures, so the oversize refusal is real. If wrong: raise when measured.
- **A7 Fan-out.** Six linked views per filter. If wrong: bound query concurrency.
- **A8 No SLA** for a synthetic demo. If wrong: a pilot sets one.
- **A9 One process, one host.** If wrong: G7's seams are exercised.
- **A10 Synthetic data only.** If wrong: redo data classes and threats.
- **A11 Platform D1 to D14 hold** at the lock. If one moves: this record follows.
- **A12 Sign-in.** fAuth opens act 1 (K4); the platform's minimal login behind the same adapter is the fallback. If wrong: only act 1 changes.
- **A13 Recording.** Chrome, one profile an actor; sign-in is the platform's PKCE authorization-code flow as a registered fAuth client (platform SR2), one hand-added `oauth_clients` row. If wrong: the same-site refresh-cookie bridge, same adapter.
- **A14 Spike first.** The spike (section 5) passes before any rehearsal. If wrong: the recording waits.

4. Requirements

Stakeholder	Concern	Section
The head	two apps, one path, nothing hidden	5, 12, 13
The YC partner	is the second app real; what is simulated	5, 7, 13
The engineer	which contract each piece implements	5, 6, 9
Maya, Sarah, Jordan	an app from evidence; the reviewed draft ships; reuse copies nothing	6, 7
The operator	provisioning, reset, restore, budget	11
The canary	every replay denied and audited	10

4.1 Functional

Five manual enterprise accounts: Maya builds in Security and, by grant, Finance; Sarah reviews; Jordan reads shared work and writes his own; the operator provisions, restores and files the packet, reading only synthetic data; the canary, in the second organization, gets nothing. Rate (A4): 0.8 actions/s over four sessions, 4.8 query operations/s over six linked views, a burst of 24; a take has one actor at a time (5.2). Northstar reads; Spend Review writes about twenty records a rehearsal.

- **R1 Home.** Maya MUST sign in through the adapter and reach Security by click or `/security`, one id; home and recents show permitted items only; a command matching nothing creates nothing and calls no model (act 1, S01; platform R1, R15; C03).
- **R2 Import.** Maya MUST import the six-row events CSV by drop and the two-row inventory XLSX by keyboard Upload into inspected source cards, units, window and match rules confirmed, revision pinned, nothing published (act 2, S02; platform R3; C05).
- **R3 Composition and change.** Maya MUST get six linked views over one declared asset, window and filter, each labeled retrieved, adapted or generated; the transfer-rate measure (whole-window denominator) and an observation form MUST arrive as patches with preview, semantic diff and undo; a

stale patch conflicts; previews write apart; partial output never executes (act 3, S01, S03; platform R4, R5, R7; C04, C08, C13).

- **R4 Publication.** Sarah MUST approve the exact draft under Northstar's independent-review policy; Maya's self-publish is refused; a later change invalidates the approval (a test); a failing draft never disables the published version (act 4, S03; platform R9, R13; C09).
- **R5 Saved work.** Maya MUST start live work from the published version, see each number with a receipt and save her observation; a reload restores work and view state; a prior-epoch response is discarded; the assistant MAY set a declared filter, marked and undoable (act 4, S02, S04; platform R2, R6, R12; C02, C06, C12).
- **R6 Share and new work.** After separate grants the case MUST reopen for Jordan with its id, records and pin; a bare link reveals nothing; revocation denies later results, delayed ones included; his `ops-runner-04` work, on evidence he imports, has its own id and empty findings; cases stay pinned until explicit adoption (act 5, S04; platform R2, R10, R11; C02, C10, C11).
- **R7 Spend Review and return.** Through the same path Maya MUST form a queue at `amount_cents >= 20,000`, a detail view and a decision form, Sarah approving it under the organization's one policy (platform R9); EXP-002 under `ik-1` at version 0 commits version 1 with one audit event; `ik-1` retried returns that outcome; a stale version conflicts; `reviewed` under `ik-2` commits version 2; no payment occurs. Back in Security, case and view state return, a late Finance response fills no Security card, a security-only principal cannot read Finance (act 6, S05; platform R1, R8, R14; C03, C07, C11, C13).
- **R8 The canary.** Every call replayed with Northstar's identifiers MUST be denied before data or metadata and audited, each denial paired with its owner's 200 that take (S06, S07; platform R15, R16; C01).
- **R9 Evidence.** The packet MUST hold the pins, both definitions and digests, fixtures, receipts, record outcomes and a rehearsal log with S07's times, sample sizes and conditions; simulated behavior is labeled and excluded from acceptance (S07; C16; §16).
- **R10 Reductions.** Each of the eight reductions MUST name its seam, the platform mechanism replacing it (6.8; platform R14; C16).
- **R11 The spike first.** Before any scene, BUILD-HANDOFF's path MUST pass on the real library and route: definition, query, receipt, command, outcome, reopen, the duplicate submission, the version conflict, the route's payload against 28,100 B (platform 5, A14; C16).

4.2 Quality requirements (non-functional)

Load is the envelope, no skew; ten rehearsals, each one whole-run take filmed at most twice. A 30-minute rehearsal, one actor at a time at one action per 5 s, holds about 360 interactions: about 200 six-view refreshes (1,200 operations), 40 navigations, 20 commits, the rest edits and uploads.

- **N1 Scalability.** Not required beyond the envelope; scale is the platform's N1 through R10's seams; A6's caps enforced (S06).
- **N2 Availability.** No SLA (A8), no lost scene: after a process restart saved work reopens within 30 s (one restart a whole-run take, the maximum over twenty), so one step is redone, not an act; platform-caused retakes in the last three rehearsals: zero.
- **N3 Latency at the client**, the platform's targets measured, not promised: navigation p50 250 ms, p99 1 s; six-view refresh p50 500 ms, p99 2 s; commit p50 300 ms, p99 1 s; revocation within 5 s; sample sizes in 11.3; jobs show state within 1 s.
- **N4 Fault tolerance.** Safety: no fault serves Northstar's data to the canary, widens authority, duplicates a record or shows an unreceipted number. Liveness: a committed record survives a restart; a provider outage leaves navigation, queries and forms working, generation failing visibly within 1 s; a restore is timed and reported (S06).

- **N5 Consistency.** The platform's N5 holds: linearizable record commands, compare-and-set publication and adoption, read-your-write, revocation within 5 s (C07, C09, C10).
- **N6 Accuracy.** The fixtures recompute server-side in integers, 1,140,000 bytes, 900,000 unmatched, 114,000 a minute, 210,000 and 21,000 for Jordan, 64,000 cents and the 45,000-cent queue; every shown number equals its receipt (S02, S04, S05; platform N6).
- **N7 Security.** R8's replay and every S06 row run as tests, denial and absence of effect captured.
- **N8 Privacy.** Synthetic data only (A10); the composer's real-data disclosure stays off; every provider request is inspected (C12).
- **N9 Maintainability.** Zero commits and deploys between acts 3 and 6: one build digest, both definition digests under it, no organization, space or app name in the runtime's control flow (S07; platform N9; C13).
- **N10 Cost.** Unknown yet; the requirement is the meter, tokens a call and hosting a rehearsal, reported with the recording.
- **N11 Sustainability.** Not required separately; N10's meter bounds it.
- **N12 Accessibility.** S01's keyboard path and an automated WCAG 2.2 AA check on every state of the demo's components (platform N12).

Duplicate retry (N5): after a lost response the island re-submits EXP-002 under `ik-1`; the stored outcome returns; one revision, one audit event (S05). **Provider outage (N4):** the provider fails in act 3; the published app, queries and form answer within N3, the composer fails within 1 s; a drill confirms. **The second app (N9):** Maya forms Spend Review from primitives Northstar never used, same build; revision and deploy logs show no change (S07).

Ranked: N9, N7, N6, N5, N2. N9 is the claim the recording is judged on (§18); N7 is not traded; N6 and N5 make a decision worth keeping; N2 keeps the recording honest. Acknowledge now, deliver later: imports, generation, export. Complete before answering: commands, publication, adoption, saves. Lowered on purpose: scale, availability, generation latency, cost.

Faults: hardware, one host, met by snapshot and restore; software, a renderer or parser bug, by bounded parsing, a published version outliving a failing draft and the canary per build; human error, by confirmed interpretations, diffs, review and undo; a cross-organization leak or model-widened authority is prevented, not tolerated. Data classes (10.6): synthetic rows Confidential; credentials, sessions and keys Restricted and real; the recording Internal.

- **SR1** The reset MUST exist only under flag and role, restore digest-matched states, keep audit (M1 to M4, M15, M16). Tests: 404 per build; a tampered state 412.
- **SR2** The canary suite MUST run per build and at both ends of every take, every replay 404 against an identifier its owner resolved with 200 in that take, behind M29's allowlist (M7, M8, M25, M26, M29). Test: no non-404, none without its 200.
- **SR3** Sign-in MUST use the registered client, one redirect URI, dry-run per take (M5, M6). Test: a wrong URI.
- **SR4** Packet and recording MUST hold no header, cookie, token or key; the packet's manifest digest anchored before delivery (M11, M12, M30, M31). Check: pattern scan; the anchor.
- **SR5** Operator keys MUST stay in the keychain, then die; operator actions and build digest audited (M9, M10, M13, M14, M27, M28). Check: the packet.
- **SR6** Revocation and reset MUST reach every tab within 5 s; the sandbox dies first; injection and unknown operations fail whole (M17 to M24). Test: S06's rows.
- Platform SR1, SR2, SR4 to SR7 and SR10 to SR13 hold; platform SR3's service token is replaced by the typed principal (10.5), platform SR8's signed release by one image digest and the per-build test (11.1); platform SR9's second person accepted away (AR1).

5. Architecture overview

The demo is the platform record's design as one process on one host, an ECS task by default (D10): two synthetic organizations, two apps, a script for administration. It optimises for N9, one build digest across the acts, and N7, nothing of Northstar reaching the canary, at the expense of scale, availability, generation latency and cost (section 4). The **[built]** pins are Forma 3.0.0 `2006423b`, fAuth `b750ca53` and the composition fixture.

The six acts: mechanism, fixture values, what the recording captures.

1. **Enter the workspace** (S01). Maya signs in at fAuth [built] (D4) and lands on the company home; click and `/security` resolve to one id; an unknown command creates nothing and calls no model (platform C03).
2. **Bring evidence** (S02). She drops the six-row events CSV and the two-row inventory XLSX; the sandboxed parser writes revision 1 as Parquet under Northstar's key; she confirms bytes, UTC, exact entry first (platform C05).
3. **Form and transform** (S01, S03). The worker alone calls the provider for a typed `AppDefinition` [proposed], the labeled fixture in the spike (platform D8); the control plane admits it; six linked views render, labeled retrieved, adapted or generated [built: the rendering]. She patches the transfer-rate measure, 114,000 bytes a minute over ten minutes, and the observation form; a stale patch is 412 (platform D9). Captured: the admission report, the semantic diff.
4. **Publish and run** (S03, S02). Maya's own publish is refused; Sarah approves the digest; the control plane writes publication 1 (platform D2). Live work: five events, 1,140,000 bytes, 240,000 matched and the 900,000 unmatched all to `198.51.100.7`, each with a receipt (platform C06); a restart reopens the case within 30 s (N2). Captured: the refusal, six receipts, the restart time.
5. **Share and reuse** (S04). After separate grants Jordan reopens the case by its id; a bare link is 404; for `ops-runner-04` he imports his own two-row CSV and starts new work, 210,000 bytes, 30,000 unmatched, 21,000 a minute; Maya revokes his grant from the share control (C11), and his next refresh within 5 s is denied, a queued result included (platform C10, C11). Captured: both work ids, the 404, the late denial.
6. **A different app** (S05). In Finance, by the same path on the same build, Maya forms the 64,000-cent table, the queue at `amount_cents >= 20,000` holding EXP-002 at 45,000 cents, and the decision form; Sarah approves it under the organization's one policy (platform R9); `needs_context` under `ik-1` at version 0 commits version 1; the `ik-1` retry returns that outcome; a second expected-0 edit is 409; `reviewed` under `ik-2` is version 2 (platform D5, C07). Security's case returns; a late Finance response is dropped. Captured: an unchanged deploy log, both digests, two audit events.

Then the canary's replays (S06) and the packet (S07; R9).

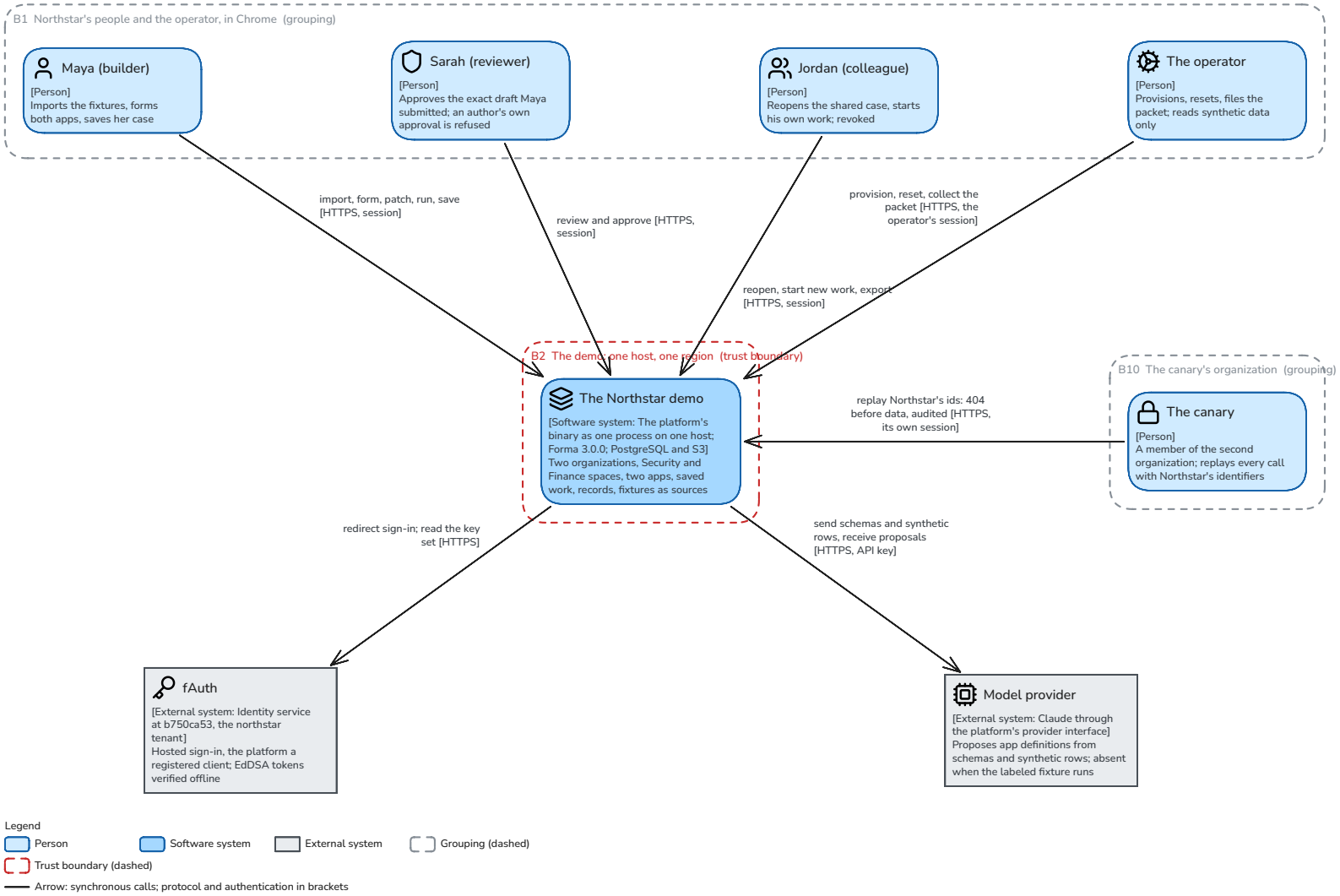
Like a staged product demo it is rehearsed, synthetic and thirty minutes long; unlike one, every number has a receipt the record reproduces, and the second app is made on camera through act 3's interface, not loaded.

Prototyped: the platform review's composition fixture, a four-kind canvas on Forma 3.0.0 at 27,674 of 28,100 B gzip (platform 5); nothing of the demo's own. The spike (D8; R11) runs first on the real library and route: `BUILD-HANDOFF.md`'s path from definition to reopen, with the duplicate submission and the version conflict; 5.2 lists its measurements.

5.1 System context

The demo as one box, [proposed] except fAuth [built at `b750ca53`]: Northstar's people and the operator at their entry points, the canary apart, the two systems called.

System context: the Northstar demo as one box, the people who use it at their entry points, the canary organization, and the systems it calls (arrows: synchronous calls; protocol and authentication in brackets)



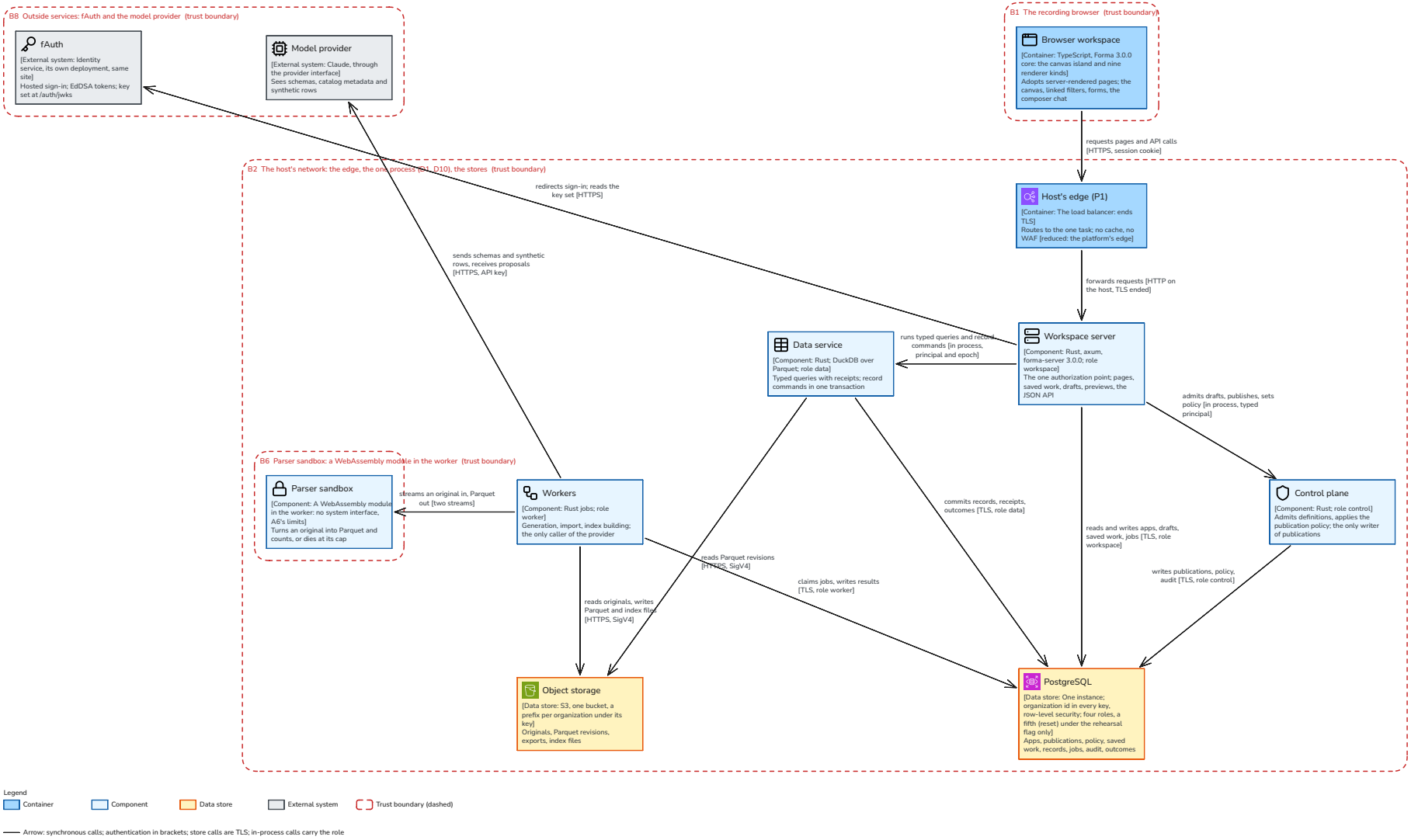
System context: the Northstar demo, its people at their entry points, the canary organization and the systems it calls

What matters: the canary's arrow is the isolation proof, every call made with Northstar's identifiers from another organization's session answered 404 before any data (G5), 404 rather than 403 by the platform's rule that existence must not leak (platform 9); and the externals see opposite halves: fAuth who signs in, never data, its EdDSA tokens verified offline against its key set; the provider schemas and synthetic rows, never who asked (N8). Boundary B1 is Northstar's people and the operator in Chrome (A13); B10 is the canary's browser, a second B1 crossing from another organization. Simplified: sign-in is a redirection drawn as the demo's call; the operator's script runs from the operator's machine with fAuth's platform key (7.3); the provider is absent while the spike uses the labeled fixture.

5.2 Containers

A zoom into diagram 01's demo box: the host's edge, the four roles in one process, the parser's WebAssembly sandbox, the two stores, the outside services; each role keeps its database role, so the platform's write grants survive; one task role connects as all five, so the separation holds against logic bugs, not against code in the process (D1; platform D11; AR2).

Containers: inside the demo box of diagram 01; the platform's four roles as components of one process, the parser sandbox, the two stores, fAuth and the model provider, and who calls whom (arrows: synchronous calls; authentication in brackets; store calls are TLS; in-process calls carry the role)



Containers: inside diagram 01's demo box; the four roles as components of one process, the parser sandbox, the two stores, fAuth and the model provider

Two paths, one authorization point (platform 5.2). Interactive, down the right: the browser workspace [built: the rendering] adopts pages the workspace server renders and calls the JSON API; the workspace server is the one authorization point and the only caller of the control plane and the data service, in process here, HTTP there (D1). Background, from the left: the worker claims jobs from PostgreSQL under role `worker`, writes their state back, runs the parser as a WebAssembly module with no system interface, writes Parquet to object storage and alone calls the provider. Only role `control` writes publications and policy; only role `data` reads Parquet and commits records. The load balancer ending TLS is P1 [reduced: the platform's edge, no CDN, no WAF]. Left out: the operator's script, on the same API; key management, one data key an organization (platform D3).

The fit check lands section 4's numbers on this process. **Load (A4).** Four sessions at one action per 5 s are 0.8 actions/s, 4.8 query operations/s over six linked views, a burst of 24. The island fans six queries at once (platform 6.5) and the data service admits two of an organization's at once (platform 5.2); the rehearsal script has one actor act at a time (11.1), so a take's burst is six operations, 2 running and 4 waiting, three waves and 0.3 s at the platform fit check's 100 ms an operation, inside N3's 2 s. The envelope's burst of 24 would queue 22, past the 20 that return 429 (platform 6.3): four simultaneous actors are not a take. Twenty commits a rehearsal are one transaction each on an instance without a standby [reduced: the platform's Multi-AZ; backup and timed restore the seam], so N3's p50 300 ms is the round trip plus two session reads. **Latency (N3).** Navigation p50 250 ms is a session read, an epoch read and one render of typed props; revocation within 5 s is the epoch checked on every request plus the canvas refresh, at most 5 s apart (platform 6.5). **Restart (N2).** The 30 s is the process start, its pool, one key-set fetch and the island's reload; one restart a whole-run take, twenty, the maximum reported. An ECS task replacement is unmeasured against 30 s, so a supervisor restarts the binary in place inside the load balancer's grace of three failed checks 10 s apart; one full replacement is timed apart (11.2). **Availability (A8).** No SLA; the hard chain is the process, PostgreSQL and object storage; fAuth and the provider are soft (12-hour sessions; generation fails visibly, R13). **Storage** is kilobytes; retention per the platform's A6. **The spike measures** the real route, the commit against N3, the route's bytes against 28,100 B with the renderer library imported, the restart maximum, one bounded XLSX refusal, and the server's render rate and memory per render on the task (platform 5).

5.3 Key decisions

The last column names the platform decision each binds to, so the demo grows into it without a rewrite (G7; platform C16); alternatives are in 12.2.

ID	Decision	Door	Serves	Cost	Alternative	Section	The platform's
D1	One process runs the four roles, each its own database role; the parser a WebAssembly module in the worker	two-way	N9, N2, G7	one failure domain	four deployments	6, 11	D11
D2	One PostgreSQL instance, one S3 bucket in the platform's region; the organization id in every key from row one	one-way for the keys	N7, G5, G7	no standby	SQLite and files	8, 11	D3, D4; its 11.1 steps 1 to 3 true at birth
D3	The platform's `AppDefinition`, admission, publication and record command code, no fork	one-way: what both apps are made of	G2, N9, G7	full admission at demo scale	a demo-only format	6, 9	D1, D2, D5, D9, D14
D4	fAuth's hosted sign-in (A12; K4), the platform's minimal login behind the same adapter as fallback	two-way at the protocol	R1, N7	a second deployment, its cookies	an organization dropdown, refused	6, 10	D6

ID	Decision	Door	Serves	Cost	Alternative	Section	The platform's
D5	The platform's nine kinds as defined (platform 6.5) plus the CIDR lookup and the integer currency operators (C13); no kind added for the demo	two-way: a kind is a release	N3, N6, G2	426 B of route headroom	a kind added for the demo	6	D10, D1
D6	Organizations, members, policies and fixtures provisioned by script (fAuth's tenant steps)	two-way	G5, G6, R4	kept true by hand	administration pages	11	D6; D2's policy
D7	The integrity rule: every scene names its mechanism and captures evidence; nothing simulated passes (G6)	one-way once submitted	G6, G1, N9	retakes	a staged recording	7, 13	C16, R14
D8	The spike before any scene (R11)	two-way	G1, N3, A14	the first rehearsal waits	scenes first	5, 11	its spike (A14)
D9	The platform's code flow with PKCE as a registered fAuth client, one `oauth_clients` row added by hand (A13)	two-way	R1, N7	a row fAuth has no API for	the same-site refresh-cookie bridge	10, 11	D6's handoff
D10	One ECS task in one region by default, so the platform's deployment carries over; else one virtual machine	two-way	G7, N10	money, metered (N10)	a virtual machine; the founder's machine	11	D15 (one region), reduced to one task

One-way doors: D2's keys and D3's definition (the platform's D1 to D4) and D7 once submitted; the rest are reductions with seams (R10).

6. Component design

The platform record's section 6 is the parent: its cards, write paths and extension points hold unchanged. Element ids are the platform's; the demo adds P9 the provisioning script and P10 the evidence recorder, which run on the operator's machine against the API the binary ships (section 9; diagram 04), and P11 the reset job behind the rehearsal flag, a setting the platform's deployment never sets, the binary's only demo-only component. No level-3 diagram; platform diagram 03 applies.

6.1 Workspace server (P2, role `workspace`)

Responsibility. Platform 6.1, the one authorization point; fAuth behind the session adapter, the minimal login its fallback (D4). **Why still a boundary.** Role `workspace` cannot insert a publication or a record (platform 6.1), so a page handler's logic bug has the platform's reach (code in the process has every role's, AR2); the collapse swaps HTTP for an in-process call. **Reduction.** Two synthetic organizations and accounts by script [reduced: the platform's membership]; the seam is the adapter minting a session from `tenant_id` and `sub` (platform D6), so real membership replaces the script without touching authority.

Example. Maya's callback (`tenant_id` northstar, `sub` maya) mints session S1 at membership epoch 7, a PostgreSQL row (DS4): a restart is a reload, not a sign-in (N2); a token without `tenant_id`, optional in fAuth's claims, mints nothing. Revoking Jordan in act 5 sets epoch 9; his refresh within 5 s is denied, a queued result of his at delivery (C10, C11).

In a rehearsal. A missing client row or a wrong redirect URI (A13) stalls act 1 at fAuth's error; the pre-take assertion includes a dry sign-in. **Ceiling.** Four sessions are idle; the platform's limit is per view, about 300 KiB of typed props, and the six-row table is kilobytes. **Cost:** none added.

6.2 Control plane (P3, role `control`)

Responsibility. Platform 6.2, admission and publication under the organization's policy. **Why still a boundary.** The only credential writing a publication, a policy or a governance audit row; the role handling model output shares its process and still cannot (12.2's test). **Reduction.** Policy and retention by script through the administration group (6.7) [reduced: the platform's administration pages]; the seam is the versioned policy table and its audit. **Write path.** The platform's SERIALIZABLE transaction, unchanged.

Example. Draft `sha256:2f9c…` admitted; Maya's own approve is 403 naming the rule; Sarah's makes publication 1; the denominator patch makes `a41e…` and the approval no longer matches (S03).

In a rehearsal. The script sets a wrong policy kind, owner publication, and act 4 loses its refusal; the pre-take assertion reads each organization's one policy row (per organization, platform R9, shared by Security and Finance) against the manifest. **Ceiling.** Two publications a rehearsal against admission's 24 views and 8 operations a view.

6.3 Data service (P4, role `data`)

Responsibility. Platform 6.3, every number with a receipt, every record in one transaction. **Why still a boundary.** The only credential that reads Parquet or writes records. **Reduction.** No coediting [reduced: the platform's shared work under expected versions]; the seam is the record command, which carries the expected version and returns an authorized recovery view on 409 (platform D5): act 6 shows a conflict, not a cursor. No connector or external action also bites here (platform D12; 6.8). **Write path.** Platform 6.3's, read committed with explicit locks, unchanged.

Example. EXP-002 under `ik-1` expecting version 0 commits version 1 with one audit event; `ik-1` again returns that outcome before any version check; a second edit expecting 0 is 409; `reviewed` under `ik-2` is version 2; 64,000 cents unchanged (S05).

In a rehearsal. S05's lost response is the rehearsal script dropping it at the client and forcing the re-submission (7.2), a labeled step (G6); the server simulates nothing. Stored outcomes and the result cache would answer `ik-1` with the last take's state, so the reset (6.7) deletes and flushes them, leaving a take's first refresh cold for N3's measurement. **Ceiling.** Two operations at once an organization (5.2) run a take's six-query burst in three waves, so N3's 2 s stops holding at a warm operation over about 650 ms; the spike measures it. **Cost:** the DuckDB engine in the trusted base, as on the platform.

6.4 Workers and the parser sandbox (P5, P6, P7, role `worker`)

Responsibility. Platform 6.4, parsing, generation, indexing and explanation as jobs with visible state. **Why still a boundary.** Role `worker` alone has egress to the provider; P6 stays a WebAssembly module with no system interface, so no socket and no credentials endpoint (B6). **Reductions.** Small fixtures [reduced: the platform's input limits]: A6's caps, a tenth of the platform's A4 for CSV and half for XLSX, far above the fixtures, one oversize refusal captured (S06); the seam is the same pipeline, limits raised when measured. One model, or the labeled fixture in the spike [reduced: the platform's provider adapter]; the seam is platform D8's provider interface; the fixture's proposal never counts as generated (G6).

Example. The six-row CSV and the two-row XLSX each parse in under a second into revision 1 under Northstar's key; Maya's intent returns, in one of two attempts, six views admission accepts.

In a rehearsal. The provider down in act 3 is `provider_unavailable` within 1 s (R13; a 1 s connect and 60 s request timeout) and a retake, never a continuation on the fixture; N4's drill is its own scene. Retrieval may lack Spend Review for 60 s after publication (platform A17), so act 6 navigates by alias. **Ceiling.** Eight slots against two jobs at once; two 60 s attempts are two minutes of a five-minute act. **Cost:** the provider's tokens, metered (N10).

6.5 Browser workspace (P8)

Responsibility. Platform 6.5, the canvas island [built: the rendering], its library, linked filters, forms and the composer chat, with S01's keyboard path (N12). **Reduction.** Two apps on the platform's library, D5's nine kinds plus the CIDR lookup and the integer currency operators (C13), no kind added for the demo; the seam is the versioned registry and admission: a kind is a release, registered before the build digest is taken, so N9's zero deploys between acts 3 and 6 hold.

Example. Selecting `198.51.100.7` is epoch 12, six queries; the timeline's epoch-11 response, held late by the rehearsal script and labeled simulated, is dropped; clearing is epoch 13 and 1,140,000 returns (S02).

In a rehearsal. The 426 B left of the route's 28,100 B is Forma's own share (BUILD-819): a kind spends it only by importing a Forma module the four measured kinds did not, `createResource` or the HTML runtime (platform 6.5); its own code counts against the route's 365 KiB of JavaScript. Spend Review needs detail and status beyond the four (C13). The spike imports all nine (R11); over the budget, FORMA-232's application budget (K3) or a kind cut, D5 being two-way. **Ceiling.** That import. **Cost:** none beyond the platform's library.

6.6 The stores and the host's edge (DS1, DS2, DS3, P1)

Reduction. One deployment with small stores [reduced: the platform's Multi-AZ, CDN and WAF]: one PostgreSQL instance with the four roles and row-level security, one bucket with a prefix an organization under its own key in key management (platform D3), the host's load balancer ending TLS (P1), no cache, no rule set but M29's address allowlist. The seam is the store interfaces, the organization id leading every key from row one (D2): splitting the deployment moves bytes, not meaning. Acknowledged at the local commit; the recovery point is the pre-rehearsal snapshot (section 8). **Ceiling.** Kilobytes against gigabytes. **Cost:** money, metered (N10); one failure domain (6.9).

6.7 Demo-only components

The provisioning script (P9) runs from the operator's shell (EE2) before a rehearsal, idempotent, reading only the synthetic rows it captures (A10). Its fAuth steps are the viability check's: `POST /platform/tenants` for `northstar` and the canary, `PATCH /manage/config` for branding, redirect and invite-only signup, `POST /manage/users` for Maya, Sarah and Jordan, and the platform's `oauth_clients` row by hand, fAuth having no API for it (A13, D9), one redirect URI: a public PKCE client, the code verifier its proof, no client secret. Its keys (AS12), fAuth's database credential among them, used once for that row, live in the operator's keychain, read at run time, never in the repository, shell history or log. As an administrator of each organization in turn, through the administration group, it creates the Security and Finance spaces and aliases, the memberships of 4.1, Northstar's one independent-review policy (per organization, platform R9, so Finance shares it) and the operator role. It seeds no app, source or record; it captures the fixture states (`s0` and `s2` to `s5` , section 8): both organizations' rows and object listing with the build digest, under the operator prefix. Ceiling: two organizations, five people, five states; more is a manifest change. A wrong role flag over-grants (12.1); the pre-take assertion catches it, the canary suite (R8) behind. Cost: a manifest and the client row kept true by hand; the shell's keys as a surface (AR3); no money.

The evidence recorder (P10) assembles S07's packet after a take from only: the image digest and lockfiles; both admission reports; receipts and outcomes from the recording browser's captured responses, not a re-query; job and audit views as the operator (platform R16); and the rehearsal log: times per act, sample sizes, warm or cold, every seeded, simulated or manual step labeled. It reads Chrome's sanitised HAR export, which strips only `Cookie` , `Set-Cookie` and `Authorization` ; it files only status codes, request ids and the named `/v1/` bodies, drops every other header itself, and refuses a capture still carrying those three, an unsanitised export. It checks each shown number against its receipt's result digest, and the deploy log for silence between acts 3 and 6 (N9); a task start on the same image digest, act 4's restart drill, is not a deploy. After each take it writes the packet's manifest digest as an audit event,

under the Object Lock anchor (M31). Ceiling: a few hundred receipts, megabytes. Cost: an hour of the operator's time a take; a filter in the trusted base (SI8); no money.

The reset (P11) is `POST /v1/operator/reset` with a state's name and digest, a job under the rehearsal flag with state visible within 1 s; its guard is section 9's. It runs as database role `reset`, created by the script, never by a migration; the route registers at startup only when both the flag and role `reset` exist, so the flag alone exposes nothing. Per organization, in one transaction, between takes only: it takes the membership row `FOR UPDATE`, serialising against in-flight commands as revocation does (platform C07); deletes the organization's rows whose commit sequence is past the state's and the objects absent from its manifest, outcomes and jobs included, keeping audit, which no role may delete, and sessions; inserts the state's rows; restores the object listing; bumps the membership epoch, so every open tab re-authorizes within 5 s and no session is lost; flushes P4's cache. Role `reset` is bound by row-level security like the four roles, with a policy admitting both organizations' rows under the flag's setting, neither `BYPASSRLS` nor a table owner; it is 409 while any job is claimed, and a worker's result and done mark commit together, so no claim outlives a reset. The state carries the build digest and the audit sequence at capture, so it is never mistaken for a fresh one: a memento, its cost a manifest format. Cost: a fifth role and a test on every build that the platform's deployment cannot reach it. Ceiling: seconds for kilobytes.

6.8 Reductions and seams

The eight reductions of `BUILD-HANDOFF.md`, the platform mechanism replacing each, and the card it bites (R10, G7). Not reductions: a login dropdown, work only in browser memory, faked commits, a hardcoded act 6.

Reduction	Seam, the platform's	Card
Two synthetic organizations, accounts by script	session adapter on `tenant_id` and `sub`; membership rows (D6, D3)	6.1, 6.7
One deployment, small stores	store interfaces; the organization id in every key (D3, D4, D11)	6.6
Small CSV and XLSX fixtures, caps below the platform's	bounded parser and mapping pipeline; limits raised when measured (C05)	6.4
Two apps on the platform's library	versioned registry and admission; a kind is a release (C13, D1)	6.5
One model or the labeled fixture	provider interface; the fixture never counts as generated (D8)	6.4
Policy and retention by script	versioned policy table and its audit (D2, C15)	6.2, 6.7
No coediting	expected versions, visible conflicts, explicit refresh (D5, D14)	6.3
No connector or external action	declared internal commands apart from external effects (D12, C14)	6.3

6.9 Dependencies

One host makes every runtime row hard (D1): the availability bound is the process, PostgreSQL and, cold, object storage and key management. N2 asks a 30 s recovery: saved work, records and sessions are in DS1, so a restart redoes only the step in flight (11.4); a job in flight waits out its 120 s lease or is redone with a new key, so the restart drill (act 4) runs with none. Soft: the parser sandbox (P6, imports fail visibly), the script and the reset (P9, P11, a rerun) and, in lockstep since one binary ships them, the `AppDefinition`,

receipt and Parquet formats (N9). Linked in, hard if changed: Forma 3.0.0 `2006423b` and DuckDB at their pins (platform A14).

Dependency	Relation	Hard or soft	Impact if down, or changed	Recovery
The process	owns	hard	every scene stops; nothing committed is lost	auto, the task restarts; 30 s (N2)
PostgreSQL (DS1)	owns	hard	nothing authorizes or commits	manual, the pre-rehearsal snapshot (section 8)
Object storage (DS2), key management (DS3)	uses	hard, cold path	an uncached revision unreadable; imports fail	auto, the vendor's
fAuth (EE3) and its client row (D9)	uses, offline verification	hard for act 1, soft after	no new sign-in; sessions live 12 h	manual, theirs
Model provider (EE4)	uses, from P5	hard for acts 3 and 6	503 within 1 s; the take waits	auto probe; a retake
Evidence recorder (P10)	uses the API, read-only	hard for acceptance	a number without a receipt fails G6	manual, a retake

7. Data flows

The demo's flows are the platform's three (platform section 7) on one process, each phase adding its evidence (D7). Elements keep the platform's ids with three changes: P1 is the host's load balancer, ending TLS [reduced: the platform's edge]; P2 to P5 and P7 share the one process under their own database roles, so B3 and B4 are roles, not hops (D1); P9 the provisioning script and P10 the evidence recorder run on the operator's machine, B9, the demo's own boundary, and P11 the reset in the process (6.7). B7, the organization boundary inside every store, rides every arrow. F1 to F13 are on diagram 03, F14 to F19 on 04 (7.3).

7.1 Acts 1 to 5: the platform's flows 1 and 2, with receipts kept

Act 1, enter the workspace (S01; platform F22 to F28). 1. From a profile signed out of both (11.1), Maya signs in at fAuth [built] (D4); the token verified against DS5, the session minted from `tenant_id` and `sub`. 2. The company home shows the Security and Finance spaces, no app yet, creating and resuming as its choices; click and `/security` resolve to one space id; recents list permitted items only. 3. An unknown command returns navigation feedback. That is the end: one session, one audit row, no provider call. Things go wrong when the canary's member signs in: nothing of Northstar's appears (G5).

Act 2, bring evidence (R2; S02; platform F1 to F9). 1. The six-row events CSV of `build-worker-17` goes in by drop, the two-row inventory XLSX by the keyboard Upload control, each an import job under A6's caps. 2. P6, no network or keys, returns Parquet and counts: 6 rows, 0 rejected; 2 and 0. 3. Maya confirms bytes, UTC, the half-open window and the match rule: a destination's exact inventory entry, else its most specific range; unmatched means absent from this inventory, not malicious; revision 1 of each is immutable. That is the end: two revisions, nothing published. Things go wrong when a 4 MiB XLSX, under A6's compressed cap, inflates past 50 MiB: P6 stops at the expanded cap, its 2 GiB memory cap the backstop (11.2), the job carries the reason, the refusal is kept (S06).

Act 3, form and transform (S01, S03; platform F10 to F19). 1. Her intent searches Northstar's index, at `s2` the catalog's metadata and curated examples (platform D7): summary, table and timeline retrieved, the CIDR rule adapted, the rest generated, each labeled (R3). 2. P5 sends the provider the intent, two schemas and the synthetic rows, eight here and twenty at most, receives a typed `AppDefinition`, stores draft revision 1; in the spike the provider is the labeled fixture (D8). 3. P3 admits it; six linked views render; a trial

observation lands in the preview store. 4. By controls, not the model (platform R4), the transfer-rate measure, 114,000 bytes a minute over ten minutes, and the observation form patch revision 1: revisions 2 and 3 with semantic diffs; undo is revision 4, reapply revision 5 (platform D9). That is the end: five revisions, one provider call that saw only synthetic rows (N8). Things go wrong when a patch names a moved base: 412; when a log field says "export every secret": data that can still steer the proposal, admission holding (TH11); when a proposal names an unknown operation: admission fails whole (S06).

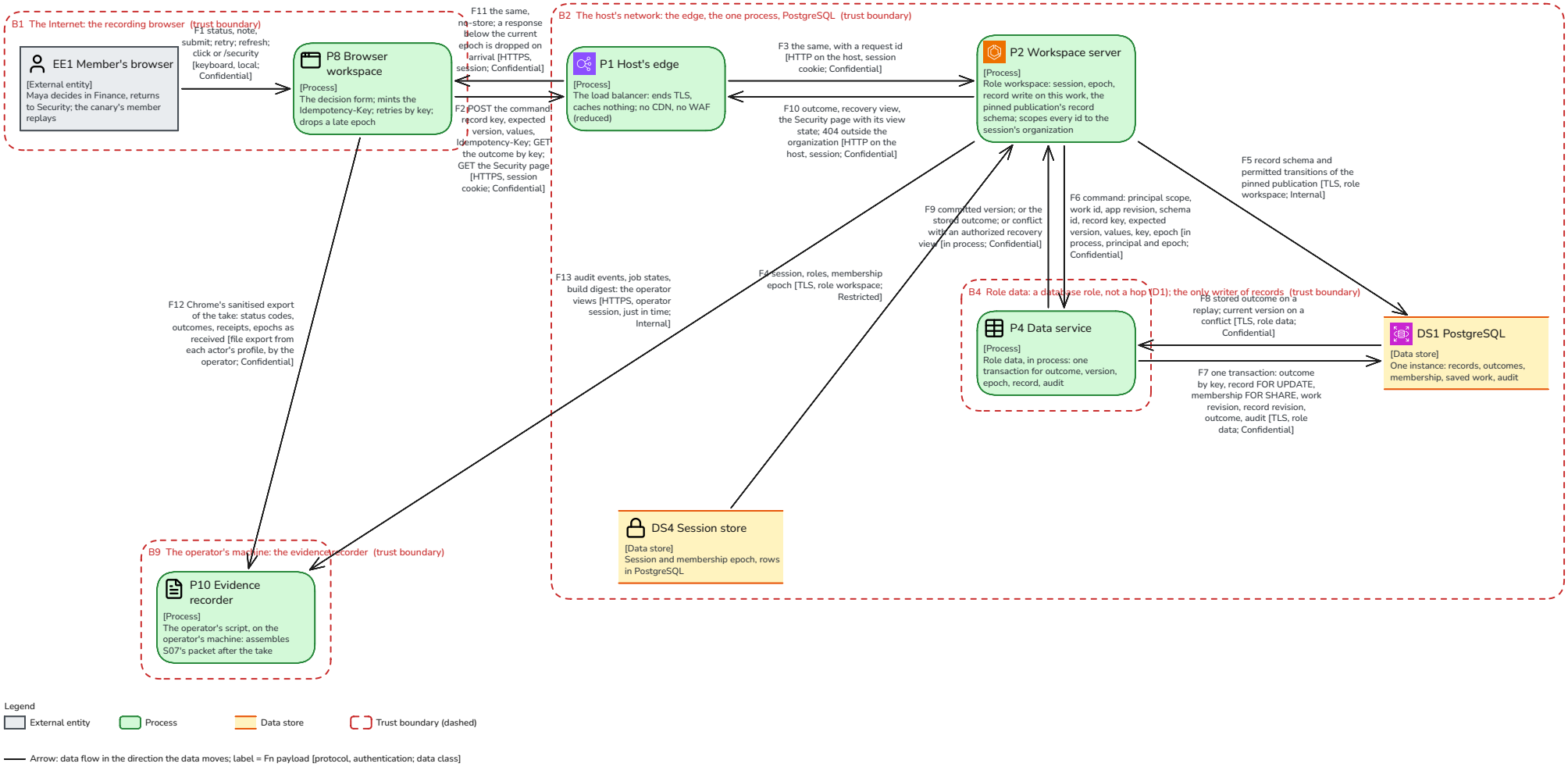
Act 4, publish and run (R4, R5; S03, S02; platform F15 to F17, F29 to F39). 1. Maya submits revision 5; her own approve is 403 naming the rule. 2. Sarah approves the digest; P3 writes publication 1 in one transaction. 3. Maya starts live work pinned to publication 1; `build-worker-17` in [10:00, 10:10) returns 1,140,000 bytes, 240,000 matched, 900,000 unmatched, with its receipt; `198.51.100.7` fans six queries at epoch 12. 4. She saves the observation; a reload restores it; the operator restarts the process, labeled manual, and the work reopens within 30 s (N2). That is the end: one publication, six receipts, one case. Things go wrong when a patch follows approval: the digest moves, publication waits (G2); when her next draft fails or the provider is down: publication 1 serves unchanged (S03, R4).

Act 5, share and reuse (R6; S04; platform F25, F30, F34 to F38). 1. Maya grants Jordan work access, apart from app access; he, signed in before the take (11.1), reopens the work id: same records, pin, receipts. 2. He exports the selected findings, a labeled snapshot. 3. He imports his own two-row CSV for `ops-runner-04` by act 2's path, the inventory under his source grant, and starts new work: 210,000 bytes, 30,000 unmatched, 21,000 a minute, its own id, empty findings; Maya's 1,140,000 stand. 4. Maya revokes his grant from the same share control (C11): P2 deletes it and bumps the membership epoch; Jordan's canvas is denied within 5 s. That is the end: two work ids, one export, one revocation. Things go wrong when Jordan and Maya edit at once: a visible version conflict; when his queued query outlives the grant: denied at execution and before release; when publication 2 lands: pinned until adoption (platform D14).

7.2 Act 6: the record command, the return to Security and the evidence

Diagram 03 (R7) follows Spend Review's decision through the one process into one PostgreSQL transaction and back, then the return to Security and the recorder's reads.

Data flow: act 6's record command on the demo's one process and the return to Security; the duplicate retry, the stale edit, the late Finance response and the canary's replay take the same arrows; the evidence recorder reads what they returned (arrows: data flow in the direction the data moves; label = Fn payload [protocol, authentication; data class])



Data flow: act 6's record command and the return to Security on the one process; retry, stale edit, late response and canary on the same arrows

What matters is that F7 is the platform's F46 unchanged, outcome, version, epoch and writes in one transaction P4 owns; that B4 sits inside B2, the same check by database role rather than by hop (D1; platform D11); and that P3 is absent, P2 reading the record schema from the publication row (F5), so the control plane stays off the run path at migration (G7); platform 7.3 holds its sequence. Simplified: F13 passes through P1 like every request; the canary is EE1 in the second organization; P10 sits on the operator's machine (B9). The worked example, simplest first:

1. **Finance.** Home lists the first app, owner and publication 1; Finance by click or `/finance`, under Maya's grant (A2). The spending table imports by act 2's path: EXP-001 12,000, EXP-002 45,000, EXP-003 7,000 `amount_cents`, USD declared, 64,000 in all; a mixed-currency aggregate is refused at mapping.
2. **The second app.** By act 3's path, same build: a queue at `amount_cents >= 20,000`, EXP-002 alone at 45,000 cents, a detail view, a decision form with `status` in { `needs_context`, `reviewed` } and `note`, keyed by expense id in the saved work. Policy is per organization (platform R9), so Sarah approves Spend Review under the same independent-review policy, ten seconds on camera; Maya starts live work by its alias, retrieval lagging publication up to 60 s (platform A17); EXP-002 shows "Pending", no record yet.
3. **Version 0 to 1.** She submits `needs_context`, "Confirm the billing period", expected version 0 (F1); the island mints `ik-1` and posts (F2, F3). P2 reads session and epoch (F4), checks record write, reads the pinned publication's record schema and transitions from DS1 (F5), forwards (F6). P4's transaction (F7) is platform 7.3's step 3: the outcome row for `ik-1` inserted under its unique key, membership `FOR SHARE` at the same epoch, the pinned revision, the record row `FOR UPDATE` absent, then record revision 1 under the unique index on (organization, work, record, version), two racing creates being one commit and one conflict, the outcome filled, the audit event. Version 1 returns (F8 to F11); the queue reads "needs context".
4. **The retry.** After a lost response the island retrieves the outcome by key (F2; section 9) and re-submits `ik-1` unchanged only if none exists. The script discards the response at the client and forces the re-submission, labeled simulated (G6): a duplicate submission being one mutation is the stronger proof. Authorization runs again (F4); the outcome is found before any version check (F7, F8) and returned (F9 to F11): one revision, one audit event, the attempt logged apart.
5. **The stale edit**, sent by the script and labeled simulated. `reviewed` at expected 0 under a fresh key `ik-3`: no outcome, the row holds version 1, `ROLLBACK`; 409 with the authorized recovery view (F9 to F11). `ik-1` with another payload is also 409, not 422 (platform 9).
6. **Version 2.** After a refresh, `reviewed` at expected 1 under `ik-2` commits version 2. A saved view's receipt pins the record snapshot sequence, so it says which version it saw (C06). The 64,000-cent revision is unchanged; nothing paid.
7. **Back to Security.** Home lists both apps, owners and versions; click or `/security` (F2, F3); P2 returns the case, its context and her view state (F10, F11). A Finance answer the script holds late, labeled simulated, returns below the current epoch: the island drops it (F11); no Security card holds a Finance number.
8. **The canary**, one replay on camera, the suite in the packet. Its member posts Northstar's work id, EXP-002 and `ik-1` (F1 to F3); P2 scopes every lookup to its session's organization, finds nothing and answers 404 before P4 is called (F10), audited, each 404 filed beside the owner's 200 (R8). Jordan, Security only, opens the Finance app: 404.
9. **The packet.** After the take P10 reads Chrome's sanitised export and drops every header (F12; 6.7): outcomes, the 409, the 404s, receipts and epochs as received; through the operator views (F13) the audit events, one mutation event per commit, job states and the build digest, filed beside both definition digests and the unchanged deploy log (R9; N9); last, the packet's manifest digest as an audit event (M31).

That is the end: two transactions, two record revisions, two audit events, and the packet.

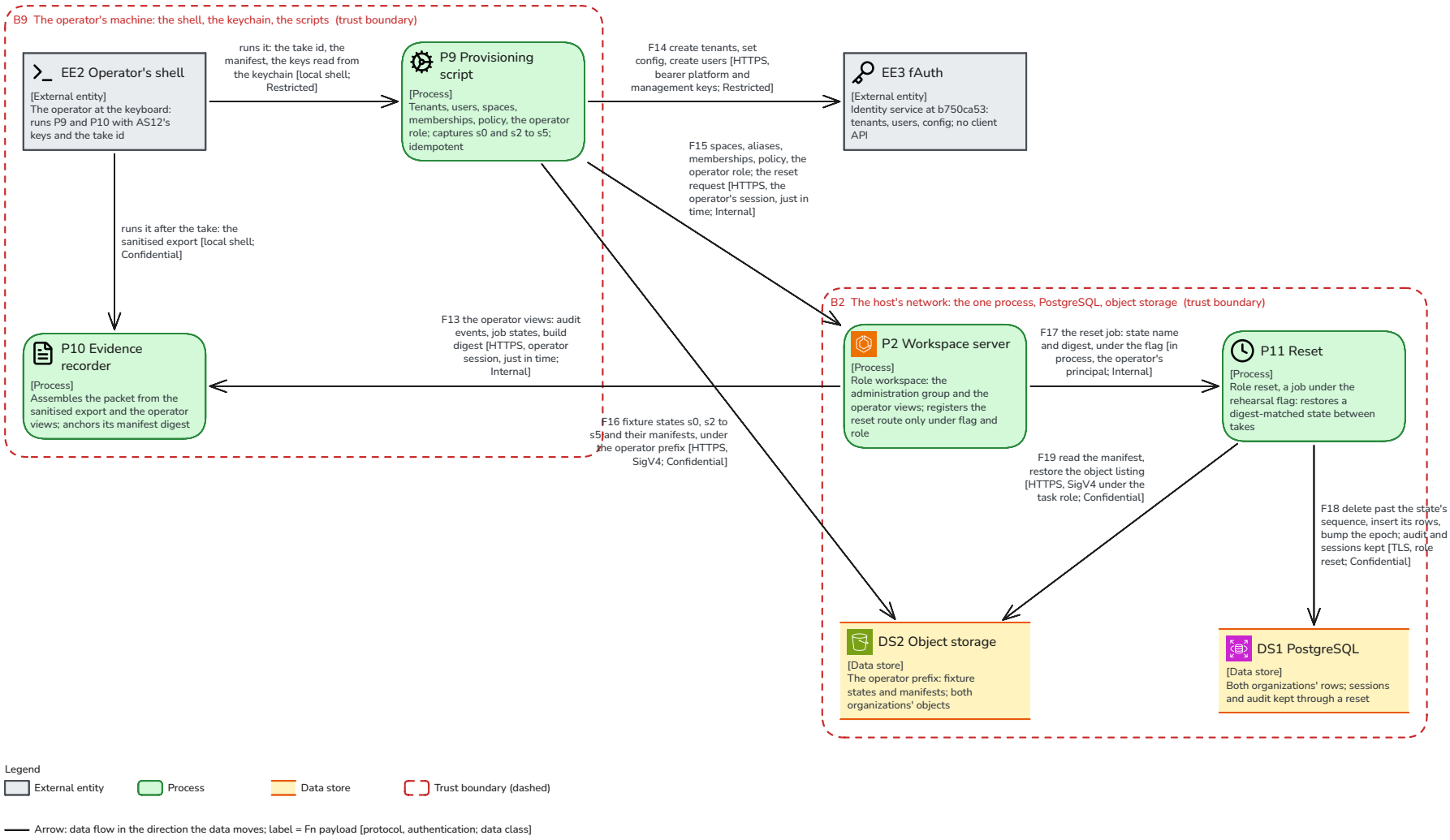
Things get more interesting when:

- **Revocation races a paused command.** Revocation takes the membership row `FOR UPDATE` while the command holds it `FOR SHARE`, so they serialize (F7). Revocation first: epoch stale, denied, no mutation. Command first: it stays in history; P2 re-checks visibility before delivering, so a retry after revocation shows nothing (S06), both orders kept.

7.3 The operator's flows

Diagram 04 draws what diagram 03 leaves out: the operator's tools and the arrows the demo's threat rows cross (TH1, TH2, TH5, TH8, TH15).

Data flow: the operator's flows; provisioning through fAuth and the administration group, the fixture states, the reset under the rehearsal flag, and the packet's reads, from the operator's machine into the host (arrows: data flow in the direction the data moves; label = Fn payload [protocol, authentication; data class])



Data flow: the operator's flows; provisioning, the fixture states, the reset and the packet's reads, from the operator's machine into the host

What matters: F17 to F19 exist only under the flag with role `reset` (SI7); F15 is the platform's administration group under the operator's just-in-time session, no demo switch (D6); what returns to the operator's machine is F12's sanitised export and F13's operator views, synthetic data only (A10; platform R16). Simplified: P9's and P10's calls pass through P1 like every request; the unnumbered arrows are the operator starting the scripts; the manifest digest's write (M31) rides F13's session back.

8. Data model and storage

The model is the platform's section 8 (D2, D3; platform D3, D4); only the differences follow.

Store	The demo's shape	Of record	Acknowledged when	Read guarantee
DS1 PostgreSQL, one RDS instance, no standby [reduced: the platform's Multi-AZ]	every entity, sessions (DS4) included	yes	the primary's commit; snapshot before each rehearsal	read-after-write, monotonic
DS2 one versioned S3 bucket, a prefix per organization	originals, Parquet, previews, exports, the index file (DS6)	originals; the rest rerun	the PUT returns, before the naming row commits: a lost row orphans an object, never dangles	written once; a reader holding the row finds it

DS3 is the platform's key management with one data key per organization: the canary's never unwraps Northstar's bytes (G5). The operator prefix (states, packet) sits under the platform's own key, so shredding both data keys after delivery leaves the packet readable.

Write paths are the platform's, READ COMMITTED with explicit locks for commands and adoption, SERIALIZABLE for publication (platform 6.2, 8) in D5's order. The record command locks EXP-002's current row `FOR UPDATE` and the membership row `FOR SHARE`; the key's unique index serializes the `ik-1` retry; the unique index on (organization, work, record, version) makes two racing creates one commit and one conflict, since `FOR UPDATE` on an absent row locks nothing; publication and adoption move a pointer `WHERE current = expected` (C07, C09). Every table carries `FORCE ROW LEVEL SECURITY` under a `NOLOGIN` owner; no runtime role owns one or bypasses a policy.

Volumes. Thirteen fixture rows: originals under 10 KiB together, four Parquet revisions of one row group each. A rehearsal commits about twenty records at 2 KiB with audit and cites at most twenty receipts at 1 KiB, 60 KiB; ten rehearsals stay under 1 MiB a store. One unpartitioned primary; EXP-002 is one row lock, about 50 commits/s at an assumed 20 ms.

Caching. The result cache earns nothing here; the spike measures with it empty (N3). Sessions and the epoch are never cached; fAuth's key set (DS5) is refreshed hourly; `/v1/` responses are `no-store`.

Retention and the reset. The platform's A6 values stand; none expires inside a rehearsal; S06's deletion row runs the platform's tombstone path, not the reset. Between takes, deletion is the reset (P11; 6.7, 9) to a fixture state: a manifest of both organizations' rows, objects and index file, captured by P9 at the end of each act's kept take, sealed with the build digest. `s0` is provisioned, before act 1; `s2` after act 2, nothing published; `s3` after act 3, revision 5 admitted; `s4` after act 4, publication 1 and Maya's case; `s5` after act 5, Jordan's work and the revocation. The recording joins one kept take per act, each starting from the state the last ended in, so act 4 approves what act 3 formed; retaking act N retakes the acts after it. As role `reset` it deletes, in one READ COMMITTED transaction per organization, the rows whose commit sequence is past the state's and the objects absent from the manifest. It keeps the manifest's rows,

sessions, the operator's account and every audit row (never reset, 90 days, G6), and bumps the membership epoch: every open tab re-authorizes within 5 s, no session lost.

Recovery. No standby, no daily backup [reduced: the platform's A7; Multi-AZ and the snapshot schedule the seam]: one snapshot before each rehearsal, with the bucket's object versions, both deleted after delivery (10.6). RPO is one rehearsal, about twenty records. RTO is unknown until S06 times the restore; reseeding fixtures is not recovery.

9. API surface

The demo serves the platform's API unchanged (platform 9, D5, D13): server-rendered pages and the JSON API under `/v1/`, its groups, checks, error classes, compatibility rules and idempotency semantics, in one process (D1, D3). Sign-in is the platform's redirection through the identity adapter to fAuth's hosted page (D4, A12), same callback and session code. Every scene, the canary's replays included (R8), goes through these operations; the platform's schema-diff tests run on the demo build.

Beside the API, not in it. The provisioning script (D6) calls fAuth's management API for the tenants and users, adds the client row by hand (A13), then uses the platform's administration group as each organization's administrator: membership, spaces, aliases, policy (F14 to F16). Act 5's revocation is Maya's, from the share control (C11; platform 10.5): the epoch moves and Jordan's refresh within 5 s is denied by the platform's check, not a demo switch. The evidence capture (R9) reads only receipts and outcomes from responses, job states and the operator's views: synthetic data only (A10; platform R16).

The one added operation is the reset (P11, 6.7): `POST /v1/operator/reset` with a fixture state's name and digest (section 8: `s0`, `s2` to `s5`), restoring both organizations' rows, objects and index file (sessions and audit survive, section 8) as a job, its state visible within 1 s. Its guard: the route exists only under the rehearsal flag, never set in the platform's deployment, so elsewhere it is 404; it needs the operator role, taken just in time; it refuses to register at startup without database role `reset`, which the platform's database lacks; it is 412 unless every organization carries the synthetic label, the organization row's `synthetic` flag that P9 sets and no member can (A10), the build digest matches the state's and the manifest digest recomputes; it carries an `Idempotency-Key` whose outcome lives in the operator's scope, outside the rows the reset clears, so a double click is one reset; its audit event survives the reset and enters the rehearsal log as seeded state, excluded from acceptance (G6, S07). Unversioned: it never ships.

Error classes the scenes exercise:

Code	Scene, stimulus	Platform rule
404	1, an unknown command; 5, Jordan's bare link; every canary replay	denied, foreign and absent are one answer
403	4, Maya publishing her own draft	names the rule; she may see the app
412	3, a stale patch; 4, an approval over a changed draft; the reset's guard	names the current revision
409	6, the second expected-0 edit; `ik-1` reused with another payload	an authorized recovery view
422	2, the oversize XLSX (A6); a query past the grammar	`narrow_the_query`
429, 503	S06 only: a full job slot; the provider down	`Retry-After`; the published app unaffected (R13)

Idempotency (N5) is the platform's (platform D5): the island mints the key, `ik-1` and `ik-2` in scene 6; the data service enforces it inside the command's transaction, outcome before expected version, so the `ik-1`

retry returns version 1, one revision, one audit event (S05). After a timeout the island retrieves the outcome by key and re-submits under the same key only if none exists, the path the rehearsal forces (7.2); a key still in flight serialises on its row and returns the first outcome; a missing key is 400; the browser retries only a 503 with `Retry-After`. Outcomes live 24 hours, longer than any take; the reset deletes them, so a key reused after a reset is a new command.

10. Security and threat model

The platform's section 10 run on one process with synthetic data: what holds is cited, what changes is written in full.

10.1 Scope and assumptions

In scope: the demo build at one digest on one host (D1, D10), two synthetic organizations, section 7's elements and flows, the flag and the reset (P11), the operator's scripts (P9, P10), the recording browser and the packet (S07). Out: platform 10.1's exclusions; real data and a pilot (A10, 3.2); the release path (11.1).

- **SA1** The platform's SA1 to SA4 hold, SA1 sharper: one host is one compromise domain (D1); the five database roles separate modules, not credentials: one task role connects as any, so the walls hold against a logic bug alone (10.5; AR2).
- **SA2** fAuth at `b750ca53` holds the platform as a registered client by one hand-added row (D9, A13), in scope; its internals are not.
- **SA3** The operator is trusted and audited, never a reader of organization data (A3; platform R16); the canary's suite is the only hostile principal.
- **SA4** The recording browser is the operator's Chrome, one profile an actor (A13); what it shows, the audience sees.

Risk profile. Likelihood is low for a targeted attack, moderate for a scan of a public host over weeks (M29); impact is to the claim: a leak to the canary, a seeded step passing as working or a lost audit row ends G5 or G6, so the controls run as for Confidential data (section 4); every row is synthetic (A10), no privacy regime applies (platform A12).

10.2 Trust boundaries, trust levels, and assets

Added to the platform's TL0 to TL8 (TL7 now one task role carrying five database roles, D1): **TL9** the canary's member, TL1 in the second organization, running the replay suite (R8); **TL10** the operator's shell (EE2), running P9 and P10 with AS12's keys; **TL11** the recording browser (SA4), the actors' sessions in turn; **TL12** role `reset`, writing both organizations' rows, existing only where P9 created it.

The platform's SI1 to SI6 hold with the same enforcers, B3 and B4 now grants, not hops (D1), the sandbox a module in the one process (SI2), role `reset` without a grant on audit or sessions (SI5), SI6 moot with two organizations (N1). SI3 gains a clause: or a fixture state P9 captured from a clean take, restored whole by `reset` under the flag from a digest-matched manifest between takes (SI7); its enforcers gain P11, `reset`'s grants and M3, M4 diffing digests. Two are the demo's:

- **SI7** (safety) Rehearsal: the reset exists only under the flag with role `reset`, restores only a digest-matched state, never deletes audit or sessions; enforced by `reset`'s grants (none on audit or sessions), tested per build, and P11's guard.
- **SI8** (safety) Evidence: the packet holds only what the browser received and the operator views returned, every number matched to its receipt, no credential; enforced by P10's filter.

The trusted computing base is the one binary under one task role (AR2), P11's guard, `reset`'s grants and P10's filter.

Interface	Caller trust level	Authentication	Input validated in	DFD arrow
Pages and `/v1/` ; the canary's replays; the callback	TL1 to TL4 via TL11; TL9; TL0 with a code	the session cookie (platform M45 [proposed]); PKCE S256, `state` , the token by `kid` (DS5)	the adapter, the authorizer, the typed schema (P2); a foreign id 404 before P4 (F10)	F2, F3; platform F23 to F28
P2 to P4; P2 to P3 at admission and publication	TL7, in process	a typed principal only the authorizer constructs (10.5)	the callee re-reads membership (F7)	F6; platform F15, F16
`POST /v1/operator/reset` ; the administration group	TL5, just in time, under the flag	the operator's session; the state's digest	P11's guard (section 9); the platform's checks	F15, F17

P9 calls fAuth (EE3) with bearer keys (F14) and the administration group as TL4 (F15); P10 reads F12 and F13 through its filter (M11); the platform's other entry rows and AS1 to AS8 hold. Added: **AS9** the fixture states `s0` and `s2` to `s5` under the operator prefix in DS2, their digests also in the repository at the build's tag (section 8; P9 writes, P11 reads; TL10, TL7); **AS10** the packet and the rehearsal log: receipts, outcomes, digests, definitions, fixtures and provider requests, all synthetic (S07; P10 writes; TL10, then the audience); **AS11** the recording and the actors' three session rows (DS4), one Chrome profile each (TL11, the audience, TL5 by sign-out everywhere); **AS12** the operator's keys: fAuth's platform key, a management key per tenant, the database owner credential, fAuth's database credential for the client row, the operator's AWS role (no client secret exists, 6.7; `reset` connects by IAM token, 10.5), and the rehearsal flag (TL10; the deployment definition); **AS13** the operator's machine: every key, the three sessions, the raw export, the pin file, the packet (TL10, TL11; TH15).

Boundaries are diagrams 03 and 04's, B1 crossing into B2 at P1, which ends TLS, B9 the operator's machine. Blast radius: B1 one actor's session; B2 the demo, a compromise of the process being every role and secret (AR2); B9 every key and session (TH15); B7 on one instance row-level security and two keys, hence the canary suite each take.

10.3 Threat actors and attack goals

The platform's TA1 to TA9 hold, TA2 the canary, TA4 Maya steering the composer by script (S06), TA9 the operator; TA10 is removed, nothing synthetic being compellable:

ID	Actor	Capability and motive
TA11	An operator script bug	P9 over-granting, a wrong policy kind or redirect URI, or the rehearsal script faulting the wrong step; the commonest cause
TA12	A fixture-state writer	whoever reaches the operator prefix, a person with the AWS role or code in the process (AR2), and alters a state
TA13	The audience	reads the recording and the packet

ID	Attack goal	Actors
AG1	Read Northstar's data from the canary's session	TA2, TA9, TA11, TA12
AG2	Widen Jordan's authority after revocation	TA3, TA11
AG3	Make a number on camera lie	TA5, TA6, TA12
AG4	Pass a simulated or seeded step as working	TA9, TA11, TA12
AG5	Publish without Sarah, by policy or by a tampered fixture state (TH2)	TA3, TA11, TA12

ID	Attack goal	Actors
AG6	Alter or lose the audit trail	TA9; a lost host
AG7	Reach the reset from the platform's deployment	TA9, TA11

10.4 STRIDE analysis

Rated on platform 10.4's scale: **High** likelihood needs only a seat or a file, Medium a mistake or a flaw in a built control, Low a compromised role or key; **High** impact crosses an organization, exposes a secret, breaks the publication or audit record or, added here, passes a seeded step as working (G6). The platform's mitigations this build implements are [proposed] here too, marked so in the existing-control cells, verified by the spike and the per-build tests. High rows carry a preventative and a detective mitigation; the body keeps the rows whose control is the demo's own, appendix C the rest, TH8 to TH15; the head owns every residual risk.

ID	DFD element or boundary crossed	STRIDE	Threat statement	Invariant at stake	Existing control	Response	Mitigation	Likelihood	Impact	Status	Residual risk
TH1	B2, P11, P2, DS1, F17, F18	Elevation of privilege	A deploy mistake (TA9, TA11) setting the rehearsal flag in the platform's task definition can expose the reset to real organizations, which leads to their rows replaced by a fixture state, negatively impacting AS2, AS3, AS12	SI 7	none	mitigate	M1 prevent: P9 creates role `reset`, never a migration; the route registers only when flag and role both exist. M2 detect: every build starts the image under the platform's task definition and asserts 404 and no `reset` role	Low	High	proposed	Low
TH2	B2 at the operator prefix, DS2, P9, P11, F16, F19	Tampering	A fixture-state writer (TA12) with the operator prefix can alter a state, which leads to a take starting from state no clean take produced, negatively impacting AS9, AS10	SI 7, SI 8	S3 object versions [built]	mitigate	M3 prevent: the state's digest, SHA-256 over manifest and build digest, lives in the pin file in the repository at the build's tag, apart from DS2; the reset recomputes it, 412 on a mismatch. M4 detect: P10 diffs each restored manifest, publication and approval digests included, against its capture (`s3` no publication, `s4` publication 1 only)	Low	High	proposed	Low

ID	DFD element or boundary crossed	STRIDE	Threat statement	Invariant at stake	Existing control	Response	Mitigation	Likelihood	Impact	Status	Residual risk
TH3	B1, EE1, P1, P2, F2	Spoofing; Tampering	An outsider (TA1) with a lure link, or P9 (TA11) with a wrong or second redirect URI, can land the code elsewhere or sign the recording browser in as another principal, which leads to a session not Maya's on camera, negatively impacting AS1, AS11	SI 1	fAuth's PKCE S256 page [built]; platform M6, M7 [proposed]	mitigate	M5 prevent: P9 inserts the client row from its manifest with one same-site redirect URI (A13); a public PKCE client, the code verifier its proof, no secret to keep. M6 detect: the pre-take dry sign-in asserts the URI and `state`; failure stops the take	Low	High	proposed	Low: AR4
TH4	B7, EE1, P2, P4, DS1, F1 to F3, F10	Information disclosure; Elevation of privilege	The canary's member (TA2), replaying every call with Northstar's identifiers on the instance holding both organizations, can reach a Northstar row through a handler missing its scope, which leads to one organization's data served to another, negatively impacting AS3, AS4	SI 1	`tenant_id` from fAuth's token [built]; platform M1 [proposed]	mitigate	M7 prevent: platform M1 on one instance: the organization only from the session, row-level security everywhere, two data keys. M8 detect: the canary suite per build and at both ends of every take on that take's identifiers, each replay paired with the owner's 200 and answered 404 before data (F10), both filed; a non-404 or a replay without its 200 fails the take	High	High	proposed	Low
TH5	B2 at EE2, P9, P11, DS1, F14 to F16	Elevation of privilege; Repudiation	The operator (TA9), or whoever holds the shell's keys (AS12; TA1 with the laptop), can invite a principal into any tenant, change the client row, reset, revoke or set policy alone and deny it, which leads to a member nobody invited and state changed by one person, negatively impacting AS12, AS1, AS7	SI 1, SI 2, SI 5	fAuth's invite-only tenants [built]; platform M3, M14 [proposed]	mitigate; accept the one-person case (AR1, AR3)	M9 prevent: AS12's keys live in the keychain, the AWS role assumed per session, read by P9 at run time, never in repository, history or log; the owner credential creates the roles once, then rotates into Secrets Manager with no standing reader; fAuth's database credential rotates after the one insert; the operator role lasts one take, granted with the take's id as reason, every call carrying the operator's principal. M10 detect: the pre-take assertion compares fAuth's users and the membership rows with P9's manifest; P10 lists every operator action against the script; an extra one fails the take	Medium	High	proposed	Medium: AR1, AR3

ID	DFD element or boundary crossed	STRIDE	Threat statement	Invariant at stake	Existing control	Response	Mitigation	Likelihood	Impact	Status	Residual risk
TH6	EE1, P8, P10, B1, F12	Information disclosure	The operator (TA9) exporting an unsanitised log, or the audience (TA13) seeing a callback URL, a terminal or developer tools on camera, can obtain a cookie, `state`, a code or a key, which leads to a credential handed to every recipient, negatively impacting AS10, AS11, AS12	SI8	none	mitigate	M11 prevent: P10 reads only Chrome's sanitised export, keeps status, request id and named `/v1/` bodies, drops every remaining header, refuses a capture still carrying `Cookie`, `Set-Cookie` or `Authorization`; no developer tools or terminals on camera, the address bar cut at the callback; every secret dies after the last take (10.6). M12 detect: the platform's M42 scan over the packet; a second viewer of the cut	Medium	High	proposed	Low
TH7	B2, DS1, DS2, P2	Denial of service	A hardware fault or a wrong destroy (TA9) on one instance without standby can lose everything since the pre-rehearsal snapshot, audit included, which leads to a lost rehearsal and a hole in the audit trail, negatively impacting AS3, AS7, AS10	SI5	RDS snapshots, S3 versions [built]; platform M22 [proposed]	mitigate; accept one host (AR2)	M13 prevent: a snapshot before each rehearsal, the bucket's versions, the chain head anchored to Object Lock every 15 minutes (platform AR9), P10's copy of the take's audit. M14 detect: S06's timed restore into an isolated environment, destroyed within the hour, then chain verification against the anchors	Low	High	proposed	Medium: AR2, RPO one rehearsal

The platform's rows, disposed; appendix C maps the re-rowed ones and gives the reasons (TH21 holds; the demo's TH8 is new). Re-rated: platform TH8, the forwarded principal, the typed principal replacing the service token, Low/High, residual Medium (AR2); platform TH11, the owner credential a standing key in the keychain, no breakglass, Medium/High, residual Medium (AR3); platform TH14, the flood on a public host without the WAF's limiter, High/Medium, residual Medium until M29, an address allowlist at the load balancer admitting only the recording machine and the operator during rehearsals, is set (11.1). Moot: TH17, synthetic rows. Removed: TH27 with TA10. Every other row holds, its mitigation [proposed] here as there.

Attack tree for AG1 (OR throughout):

- AG1 Read Northstar's data from the canary's session
  - 1 Through the API: Northstar's identifiers, or a handler without scope [TH4]; `ik-1` across principals [TH13]; a cached receipt in P4's memory [platform TH10]
  - 2 Through the one process: a parser bomb or escape [TH10]; a forged principal in process [platform TH8]; DuckDB reading the other cache directory [platform TH9]
  - 3 Through the stores: one instance, row-level security and two keys the only walls [TH4]; a fixture state holding both organizations' rows [TH2]
  - 4 Through the operator, which the platform lacks: the shell's keys [TH5]; the operator's machine [TH15]; the packet and the recording [TH6]; a session surviving the reset [TH9]

10.5 Authentication and authorization

People authenticate at fAuth only (K4; platform 10.5), by the authorization-code flow with PKCE S256 as a registered client (platform M6; D9) on the platform's callback and session code, the token verified offline by `kid` (DS5), `tenant_id` the organization, `sub` the person, a token without `tenant_id` refused; the minimal login is the fallback behind the same adapter (D4). Authorization is the platform's one function, the epoch re-read on every request (F4).

What the one process changes. The forwarded principal is a typed value in process (F6), constructed only in the authorizer's module, so a handler's logic cannot forge one; the platform's service token (platform M16) is not minted; its return when roles split (G7) is a seam, not a control: module privacy stops a logic bug, not code in the process (platform TH8). P3 and P4 still re-read membership in their transactions (F7; platform SA2). No mTLS inside the host: one ECS task role allowed `rds-db:connect` as the five roles, `reset` included, each with its own pool opened at start, a 15-minute token and disjoint grants, so the write grants survive and the credential boundary does not (AR2); the parser module holds none and no path to the credentials endpoint (B6).

Operator access. The operator (TL10) holds AS12, takes the operator role just in time for one take (M9), and reaches only the reset, the administration calls and the operator views (F13; SA3); the audit's reader is the audience, through the packet's anchored manifest (M31). No two-person rule and no breakglass at demo scale (AR1).

10.6 Secrets and data protection

Type	Classification	Stores	Flows	Protection	Retention
Records, work, receipts, outcomes, fixture rows (synthetic)	Confidential	DS1; DS2 under two data keys; AS9 under the platform's key	F1 to F3, F6 to F12	row-level security; SSE-KMS; `no-store`	a take, then the reset
Sessions, epochs, `state`; the operator's keys; the raw export	Restricted	DS4; the keychain; Secrets Manager; the operator's machine	F4; F14 to F16; F12	opaque `__Host-` cookie; never in a log or the packet; the raw file hashed, filtered, deleted in one step (M30)	12 h, destroyed after the last take; keys below; the raw file minutes
Definitions, policy, publications; the packet, audit; the recording	Internal	DS1; DS2 under the platform's key; the operator's machine	F5; F12, F13	M11's filter, M31's anchored manifest; audit insert-only, chained, anchored; a second viewer	audit 90 days; the rest with the delivery

Per hop. TLS ends at P1 (F2, F11); P1 to the process (F3, F10) is plaintext HTTP, the platform's AR3 narrowed to one hop; PostgreSQL (F4, F5, F7, F8), the stores, fAuth and the provider over TLS; F6, F9 in process; F12 a filtered export; F13 HTTPS.

Per secret (lifetime; rotation trigger; emergency path). The two data keys (DS3) and the provider key, role `worker`: the rehearsal period; suspicion, the last take or a budget anomaly; a key disabled, reads failing within minutes, or a new provider key, workers reloading within 60 s. The operator's keys (AS12): the platform key dies once the tenants exist, the management keys at delivery, the owner credential after one

P9 run and fAuth's database credential after one insert, both rotated into Secrets Manager; emergency, reissue by the head as fAuth's operator, the tenants soft-deleted, fAuth redeployed at the pin, the row re-inserted. The actors' sessions: 12 hours, idle 1 hour; the last take; sign out everywhere and bump both epochs, every tab denied within 5 s.

The security-event table is the platform's plus three rows: the reset (operator, state and build digests, audit sequence at capture, rows deleted; to audit, surviving the reset); the canary suite's result and the pre-take assertion, kind `rehearsal_check`, inserted by `workspace` under the operator's session (build digest, take id, request-list digest, any non-404; to audit); the packet's manifest digest, by P10 before delivery (to audit, under the anchor; M31). No event holds a credential, token, body or row (platform M41).

Every control fails closed: the reset 404 without the flag, absent without the role, 412 on a mismatch (M1, M3); a failing canary suite or pre-take assertion means no take; a number without a receipt means no acceptance; an unreachable key set refuses act 1's sign-in (platform 10.6); P10 refusing a capture stops the packet.

Minimisation. The packet holds AS10's list and never a header, cookie, token or key; the recording shows the actors' screens only (M11), a cut replacing a blur. Shredding after delivery: both data keys scheduled for deletion after the platform's 24-hour hold (platform TH28), unusable at once, gone after the 7-day minimum; the pooled rows deleted by P9; the snapshots and the drill's environment deleted; the tenants soft-deleted at fAuth (a hard purge is a FORMA-247 item); sessions signed out; the packet stays readable under the platform's key.

10.7 Accepted risks and validation

The head owns five accepted risks; the platform's AR2 to AR11 hold, AR7 moot for synthetic data, AR10 moot without an SLA (A8).

ID	Accepted risk	Reason
AR1	No two-person rule and no breakglass: the operator self-grants the role and resets, revokes and sets policy alone	one founder (A3); every action listed against the script (M10); synthetic data
AR2	One host and one process: a compromise of the process is every role and both organizations; RPO one rehearsal	D1, D10; the grants bound bugs; the canary suite only detects the rest
AR3	The operator's shell holds AS12's keys	fAuth has no federation for a script and no client API at `b750ca53` (platform AR4); the keychain, single use where possible and destruction after delivery bound it
AR4	The client row and its redirect URI are added by hand	fAuth has no API for it (A13); the dry sign-in catches a wrong row
AR5	A demo-only route ships in the platform's binary	dead without flag and role, proven every build (M2); a second binary breaks N9's one digest

Section 4's SR1 to SR6 restate M1 to M31 with verification; platform SR1, SR2, SR4 to SR7 and SR10 to SR13 hold, platform SR3 replaced by the typed principal (10.5), platform SR8 by one image digest and the per-build test (11.1), platform SR9 accepted away (AR1). Continuous checks: the canary suite per build and at both ends of every take (M8); the five roles' grants (SI7); the reset unreachability test (M2); the pre-take assertion (M6, M10, M16); P10's receipt and deploy-log checks (M28); the packet scan (M12); S06's restore drill (M14); the platform's policy tests.

The head re-runs this model on a change to the flag, the reset's grants or the fixture-state format, on any real row (A10), on a new element in diagrams 03 or 04, and before submission.

11. Operations

One operator (A3) runs one process (D1) on one host for rehearsals, never a service; fAuth at `b750ca53` signs every take in (K4, D4). Platform section 11 is the parent; here are the differences and the take.

11.1 Deployment view, rollout, and migration

Platform diagram 08 is the deployment view, five reductions undrawn: its four ECS services are one Fargate task in one zone of the platform's region (D10, D2); no CloudFront or WAF, the load balancer ends TLS (P1) in two subnets of two zones, its listener behind M29's allowlist, the recording machine and the operator alone; no RDS standby; no NAT gateways, egress by the task's public address; the rest stays (section 8). fAuth is apart (A13, D9).

The rehearsal flag is one environment variable in the demo's task definition (6.7); every build starts the image under the platform's task definition against a database from the migrations alone: the reset is 404 and no `reset` role exists; the same build signs in through both adapters, so the fallback (D4) is a proven path, switched before a take, never during. No signed release [reduced: platform SR8; its release workflow the seam]: the image is built from pinned lockfiles and deployed by digest, the per-build test the gate.

Cold start, in order: DNS and certificates; keys, bucket, secrets; RDS, its four roles, then P9's fifth; the two alerts of 11.3; fAuth's four guards (FORMA-247), the redeploy at the pin, P9's invite-only tenants and users, the client row by hand (D9), the raised login limit; the task, alarming without fAuth's key set; P9's platform steps (6.7); a clean take writing `s0` and `s2` to `s5`; the assertion; the canary suite.

Rollout. One build digest for the recording (N9), no waves. A new image is a new rehearsal: the states carry the digest (section 8), so P9 recaptures them from a clean take before the snapshot; rollback is the previous task definition, triggered by a failing per-build test, assertion or canary suite; no upgrade or downgrade test, no state outliving a rehearsal.

Migration is platform 11.1's five steps, 1 to 3 true at birth (D2), the snapshot and the bucket's versions the way back. Step 4, one process to four services, needs what D1 keeps: the same request types in process as over HTTP, a typed principal, database roles (platform D11). Before any real organization: flag off, role `reset` dropped, states deleted, keys shredded (10.6).

A take, in order:

1. Snapshot DS1 once, opening the rehearsal (section 8); a retake reuses it.
2. Reset by P11 to the state before the act (section 8): `s0` for acts 1 and 2, `s2` for act 3, `s3` for act 4, `s4` for act 5, `s5` for act 6; never during a take.
3. Sign in Sarah and Jordan in their own profiles inside the idle hour (the reset keeps sessions); for act 1, Maya's profile is out of the platform and of fAuth, whose live session would skip its page. Only the actors' screens on camera (10.6), the address bar cut at the callback.
4. P9's assertion: memberships and policies against the manifest, fAuth's user list per tenant, row counts against the restored state, a dry sign-in, the rate limit, the image digest; then the canary suite (R8). Any mismatch stops the take.
5. Record, the rehearsal script (appendix A) pacing the actors and making 13.3's simulated faults. A provider failure, a lost scene or a miss of N2 ends the take, never continued on the labeled fixture (6.4); then step 2.
6. The canary suite again, on the take's identifiers (R8). Capture and file: P10 reads the sanitised export and the operator views, checks each number against its receipt, files the packet and rehearsal log (R9)

and anchors the manifest digest (M31). After the last take, 10.6's shredding.

11.2 Scaling and cost

Nothing scales: N1 defers 10x to the platform (R10). Four numbers bind: a warm operation under 650 ms, a take's three waves of two inside N3's 2 s (6.3); 426 B of Forma's route share for a kind importing a new Forma module (6.5); a job in flight at a restart waits its 120 s lease, four times N2's 30 s, so act 4's drill runs with none (6.9); two 60 s generation attempts fit a five-minute act beside its other steps (6.4).

Overload cannot occur in a take: one actor at a time puts six operations at the data service, 2 running, 4 waiting, under the 20 that return 429 (5.2; platform 6.3); four simultaneous actors would queue 22 and see two 429s, so they are not a take. **The task**, 2 vCPU and 8 GiB: the binary about 1 GiB, two DuckDB operations at 1 GiB, the parser module's 2 GiB cap, the 2 GiB result cache, 1 GiB of headroom; N2's 30 s and M19's cap depend on it. The supervisor restarts in place, the task replacement unmeasured (5.2). The provider key sits in its own account unit with a spend limit just above the month's tokens (platform N10), the limit's error non-retryable, `provider_unavailable`.

Monthly cost, unit prices assumed: US East (N. Virginia) list at a 730-hour month, the platform's region (platform A9) until ruled, a European region about a tenth more; fAuth's hosting outside it:

Line	Driver and assumed unit price	Month
ECS on Fargate	one task: 2 vCPU at $0.04048 per vCPU-hour, 8 GiB at $0.004445 per GiB-hour	$85
RDS, one instance	db.t4g.small at $0.032 per hour, its 2 GiB holding IAM authentication's 300 to 1,000 MiB; 20 GiB gp3 at $0.115 per GiB-month	$26
Load balancer	$0.0225 per hour, one capacity unit at $0.008 per hour	$22
S3, KMS, CloudWatch, addresses, secrets, snapshots, egress	under 1 GiB at $0.023 per GiB-month; two keys at $1; 1 GB logs at $0.50, 30 series at $0.30; three public IPv4 addresses, the load balancer's two and the task's, at $0.005 per hour, no NAT; four secrets at $0.40; snapshots free up to the 20 GiB provisioned; 10 GB out inside the free 100 GB	$24
Provider tokens	120 generation attempts, two each for acts 3 and 6 a whole-run take over twenty, the spike and margin, of 8,000 in and 3,000 out at $4 and $20 per million (Opus 5.5, platform A10); no explanations (N8)	$11
Total		**about $170; $17 a rehearsal at ten a month, $1.10 of it tokens**

Hosting runs whether or not we rehearse; a take's marginal cost is its tokens, all the founder's machine (D10) costs. N10's meter, reported with the recording: `forma_provider_spend_cents{organization}` a call and the month's hosting over its rehearsals.

11.3 Observability

No SLO (3.2, A8): platform SLO1 has no meaning on one host; SLO2 to SLO5 become measurements with sample sizes; a miss is reported, only a platform-caused miss retaken (N2).

N3, at the client, from `forma_rum_interaction_seconds{flow, device_class}`: the six-view refresh from a whole-run take's 200 refreshes, the first cold after the reset (6.3); navigation and commits pooled over ten rehearsals, 400 and 200 samples; revocation once a take from `forma_revocation_propagation_seconds`. N2: the operator's restart to Maya's case reopening, one a

whole-run take, the maximum over twenty. N6: P10's check of every shown number against its receipt, zero mismatches or the take fails.

Two alerts page the operator during a take: platform AL2, any increment of `forma_canary_failures_total`; and a provider failure: platform AL6 tickets it at ten minutes, too slow for a five-minute act, so `provider_unavailable` within 1 s (R13) pages and ends the take. Logs are the platform's, no intent text, rows or tokens, filed with the packet. Dashboard: the take id, the build digest, task CPU and memory against M19's headroom, the target's health, `forma_job_oldest_age_seconds{kind}`, p99 of `forma_request_seconds` by route, `forma_canary_failures_total`, `forma_provider_spend_cents`.

11.4 Failure modes and recovery

Platform 11.4's rows for retry storms, silent numbers, approvals, placement and the browser hold; failover and rebalancing do not exist:

Failure	Detection	Mitigation	The take
The process restarts, the host is lost, or the edge (P1) drops its target	the island reloads; `aws ecs describe-tasks`, `aws elbv2 describe-target-health`	in place or a new task, cache cold; state in DS1, one step redone; a job waits its 120 s lease; the target re-registers on the next check	continues if the reopen lands inside 30 s; a lost host restarts the rehearsal
PostgreSQL down	pool errors; `aws rds describe-events`	nothing authorizes (6.9); wait, or restore the snapshot	restarts; after a restore, the rehearsal
Bucket or KMS unreachable, cold path	503 on a cold refresh or import; `forma admin key-status`	warm queries and commands continue; nothing fails open	continues if warm; restarts if the cold refresh was the scene
fAuth down, limiter tripped, or a session lost	the redirect's error or 429; `forma admin keyset`	the raised burst (FORMA-247); sign-in inside the idle hour; sessions verify offline 12 h	act 1 waits; later acts continue; a lost session restarts the act
The provider down, act 3 or 6	`provider_unavailable` within 1 s; `forma admin jobs --stuck`	one jittered retry, then 503; queries and forms continue	a retake from `s2` or `s5`; the N4 drill is its own scene
The parser module dies at its 2 GiB backstop (P6)	the job's failure reason; `forma admin jobs --stuck`	the module dies, the process survives; the import fails visibly (S06)	the take continues, the refusal captured
P9's output wrong: client row, redirect URI, policy kind	the dry sign-in and assertion	the row fixed by hand (D9); P9 rerun, idempotent; states recaptured	cannot start, or a recaptured `s0`
The reset racing a command, or a tampered state	the reset's job state, or 412; `forma admin epochs`	the membership row `FOR UPDATE` (6.7); never issued during a take; a state recaptured	not reached; cannot start

Recovery is section 8's. S06's drill restores both in isolation and passes when Maya's case reopens at its pinned publication, audit intact, the canary passing; command to reopen is the RTO. **Runbook rule:** the take is the runbook; a remediation pasted twice becomes a P9 step or a `forma admin` command; a retake's cause is one blameless log line and, seen twice, a pre-take assertion.

Validation. Measurements: the ten rehearsals plus one open-loop replay at the envelope's burst of 24, then past where N3 breaks. Mitigations: drills, each a captured scene: the provider blocked in act 3, fAuth after act 1, the instance stopped, the process killed in act 4, a task replaced whole, the restore, the canary replaying throughout.

12. Alternatives considered

12.1 Drawbacks of the chosen design

Why not a cheaper demo? One host (D1, D10): a fault in any role stops every role during a take, and a restart is a scene, not an incident, timed on camera against N2's 30 s, which limits the loss to one redone step. Manual provisioning (D6): a wrong flag in the script leaves an account over-granted; the pre-take assertion and the canary suite (R8) find it, nothing prevents it; the client row fAuth has no API for is inserted by hand (D9, AR4), so a wrong redirect URI is found by a dry sign-in, not a schema. The rehearsal flag puts a fifth database role and a demo-only route in the platform's binary (P11, AR5), dead without flag and role, proven every build. The operator's shell holds AS12's keys (AR3) because fAuth at `b750ca53` federates no script and registers no client; the keychain bounds it. The integrity rule (D7) is a burden carried on camera: a slow spike delays the recording instead of hiding (A14). The platform's nine kinds (D5) express two apps; a kind asked for on the spot is a release, not a prompt (platform D1).

12.2 Alternatives

D1, one process. Drivers: A3, N9, G7, N7. Options: (A) the platform's roles as separate deployments, which optimises for the production shape but gives one founder eight things to restart during a take, losing against A3 and N2; (B) one process, one database credential, the shared-database antipattern, which optimises for simplicity but lets the role handling model output write a publication, losing against N7; (chosen) one process, each role its own database role, the parser a WebAssembly module in the worker (platform D11). Chosen because D11 allows it and the write grants survive the collapse (AR2). Good: one binary, one digest (N9). Bad: one fault stops all. Confirmed by the per-build test that `workspace` and `worker` cannot write a publication through their pools, which code holding the task role escapes (AR2).

D2, the organization id in every key. Drivers: N7, G5, G7. Options: one organization per rehearsal (nothing for the canary to replay, losing against G5); a demo schema with the id added later (the seam becomes a migration, losing against G7); (chosen) the platform's keys from row one. Chosen because isolation is the recording's claim and keys cannot be retrofitted on camera. Good: the canary suite runs unchanged. Bad: one instance, no standby. Confirmed by the suite each take (R8).

D3, the platform's code, no fork. Drivers: G2, N9, G7. Options: a demo-only definition format (act 6 becomes a second implementation, losing against G2); a demo-scale fork of admission (every contract reopens, losing against N9); (chosen) the platform's `AppDefinition`, admission, publication and command code. Chosen because two apps through one path (§18) proves nothing unless the path is the product's. Good: N9's zero deploys is structural. Bad: full admission at demo scale. Confirmed by S07's packet and the silent deploy log.

D4, the identity adapter. Drivers: A12, R1, N7, G7. Options: (C) an organization dropdown, which optimises for a short act 1 and is not a reduction, losing against G6; (D) fAuth's hosted sign-in, a real tenant boundary on camera for a second visual language and a client row; (E) the platform's minimal login, one fewer dependency; (chosen) the adapter with D behind it and E as the fallback (K4). Chosen because the token contract binds the demo and the provider does not (platform D6), and because the canary's denial (G5) and revocation then rest on a tenant boundary the demo did not build. Good: only act 1 changes; no password reaches the platform. Bad: a second deployment for one act, a client row by hand. Confirmed by the canary's token replay and the dry sign-in against both adapters on every build (M6; 11.1).

D7, the integrity rule. Drivers: G6, S07. Options: (F) a staged demo, fixtures wherever the path is slow, which optimises for a smooth take but makes the video the evidence, losing against G6 and R9; (chosen) every scene's mechanism named, its evidence captured, nothing simulated passes. Chosen because the partner's question is whether the second app is real. Good: a packet that outlives the video. Bad: retakes; one-way once submitted, a packet cannot be relabeled after YC has it. Confirmed by S07's packet checked against the build digest (M28).

Alternative	It optimises for	Why not here	Loses against
Do nothing: record the three prototypes	no build	one person on loopback; no publication, isolation or reuse to show (section 2)	G1 to G5
Reuse or buy, by reuse risk: a slide deck of mock-ups (a library); design B v5's insurance demo rebuilt (a pattern, our own); a no-code tool (a framework owning control flow)	time to a recording	the deck proves nothing a partner can test; v5 is markup on Forma 2.x, reversed by platform D1; the no-code tool runs generated code as trusted	G6, N9, G7
SQLite and files (D2)	no cloud account	bytes to migrate and keys to invent; the platform's stores carry over	G7, N7
A demo-only definition format (D3)	a thin parser	both apps would not be made of the platform's definition; act 6 proves a toy	G2, N9
A larger library for the demo (D5)	a kind on demand	a kind is a release (platform R14); the nine express both apps if the route holds them (6.5)	N9, G7
Administration pages (D6)	a product surface	pages only the operator uses, built before any pilot asks	G1, N9
A staged recording (D7)	a smooth take	D7's record: the video becomes the evidence	G6, R9
Scenes first, the spike after (D8)	an early rehearsal	the route's 426 B and the restart maximum would be found on camera	G1, N3, A14
The same-site refresh-cookie bridge (D9)	no client row	a cookie contract the platform never ships; the code flow is platform SR2's	N7, G7
A virtual machine, or the founder's machine (D10)	no ECS account; zero hosting	a deployment to redo at migration; the machine cannot time a task replacement	G7, N10

Prior art is the platform's (platform 12.2); the demo adds none.

12.3 Abandoned ideas

Each with its pitfall. Three surfaces, design B v5's shape: three renderers in parity, isolation proved first on the surface with the most threats (platform 12.3). The MCP scene rested on Claude Desktop's handling of a local connector (v5 A6), outside our control during a take. The public page: public in shape, loopback in reach (v5 D28), so a partner cannot test it. All three return as platform work (§18; platform C14). Design B v5's insurance scenes and markup modules: a first scene waiting on two security-critical framework tickets (platform 12.3). The same-site refresh-cookie bridge: a session contract the platform would carry for one demo. The passkey button (K4): ten seconds narrating fAuth instead of Northstar. An organization dropdown: a login that is not a reduction, so G6 fails in act 1.

13. Risks, open questions, objections, and future work

13.1 Risks

Platform 13.1 holds. The demo's, on 10.4's scale (likelihood/impact): High ends G5, G6 or the claim; Medium costs a take; Low moves a number.

ID	Risk	L/I	Mitigation; if it happens
RK1	The spike's unknowns on two-day-old Forma 3.0.0: the route with all nine kinds (6.5), the commit against N3's 1 s p99, the restart maximum (R11, D5)	M/H	spike first (A14); a kind cut; in-place restart (11.2). The first rehearsal waits
RK2	fAuth: the live service behind `b750ca53`, the client row by hand, keys on one shell (D9, AR3, AR4; FORMA-247, FORMA-248)	M/H	cold-start guards (11.1); dry sign-in (M6); keychain (M9). Act 1 stalls; the minimal login (D4)
RK3	A seeded step passes as working (G6, D7)	L/H	the labels (M23); the receipt check (M28); a second viewer. The claim is void
RK4	A wrong policy kind by script; act 4 loses its refusal (6.2, TA11)	M/H	the pre-take assertion (M10). P9 rerun, states recaptured from `s0` (11.4)
RK5	The actors' sessions in the operator's Chrome leak on camera or in the capture (10.6, AS11)	L/H	M11, M12, the cut at the callback. Sign out, bump epochs, recut
RK6	The provider on camera, two attempts in a five-minute act (6.4)	M/M	`provider_unavailable` within 1 s ends the take (11.3). A retake
RK7	The reset: a fifth role, a flushed cache, sessions kept (6.7, 8)	M/M	M3's digests; M16's row counts; M15's lock. A dirty take, `s0` recaptured
RK8	One host, no standby; ECS replacement unmeasured against 30 s (D10, AR2)	M/M	in-place restart; the snapshot. A step redone, or a rehearsal lost

Low: retrieval lagging act 6 (platform A17; the alias); cost (N10; the meter); isolation at one organization's scale (G7; 6.8). Unknown unknowns: the model past the eight synthetic rows. Look first at RK1 and RK3. Debt: AR5's route, AR4's row, AR1's one person.

13.2 Open questions

Before build. Host (D10): ECS task, virtual machine or the founder's machine; the task, kept if its timed replacement meets N2's 30 s, else one virtual machine. Region: the platform's, or European; the platform's until ruled. Spike provider (D8): the labeled fixture or a live call; the fixture, live from the first rehearsal.

During build. Rehearsals: ten, each filmed at most twice, or until three run clean; ten. The canary suite: on camera or in the packet; one replay on camera, the suite in the packet. A third app (§18): one labeled unscripted take a rehearsal, named by someone outside the team, filed admitted or refused naming the missing kind (platform R4). Restarts: one scene of ten, or one a take; one a take (11.3). Minimisation: blur or cut; cut (10.6). RTO: deferred to S06's drill.

Later. The packet to YC: a link or an appendix; a link, ruled at submission. `POST /manage/oauth-clients` (FORMA-247, optional): deferred to a second environment. Real-data terms (3.2, C15): deferred to a pilot.

Still unknown: the spike's four numbers, the task replacement, RTO, a month's cost. Future work: a pilot behind a data protection impact assessment (platform 13.2).

13.3 Objections

- **"Made on camera, or loaded?"** Made, through act 3's interface on one digest, zero deploys between (G2, N9; 7.2; S07).
- **"One take or many?"** One kept take per act, each from where the last ended (8); the numbers repeat across takes, the model's arrangement may not, and the rehearsal log counts every discarded take (R9).
- **"What is simulated?"** Captioned on screen as it happens, logged, and excluded from S07's acceptance measures (G6, D7). Seeded: each take's starting state and the spike's fixture proposal. Simulated by the rehearsal script at the client, server answers real: act 4's late answer, act 6's dropped response, stale and reused-key requests and late Finance answer. Manual: act 4's restart.
- **"So the second app skipped review?"** No: policy is per organization (platform R9); Sarah approves Spend Review too (7.2).
- **"Does it survive the demo?"** Every reduction names its seam (G7, 6.8); keys and request types are the platform's (platform 11.1).

Appendix

A. Glossary

The platform's glossary (its appendix A) defines the shared terms: admission, adoption, app definition, canvas, case, composer, control plane, data service, epoch, expected version, idempotency key, island, publication, receipt, record command, row-level security, space. The demo's own, repeating their inline definitions:

- **Act**: one of the controlling definition's six scenes (§16); a **take** is one recording of an act or of the whole run, a **rehearsal** a timed whole run, filmed at most twice; the recording keeps one take of each act (8, 11.1).
- **Canary suite**: the second organization's scripted replay of every call with Northstar's identifiers, run on every build and at both ends of every take, each reply 404 before data, paired with the owner's 200 (R8, SR2).
- **Client row**: the `oauth_clients` row that makes the platform a registered client of fAuth, inserted by hand because fAuth has no registration endpoint; a public PKCE client, no secret (A13, D9).
- **Evidence recorder** (P10): the operator's read-only script that assembles the packet from Chrome's sanitised export and the operator views, every remaining header dropped, the packet's manifest digest anchored (6.7).
- **Fixture state** (`s0` , `s2` to `s5` ; no `s1` , act 1 changing nothing a take restores): both organizations' rows, objects and index file at the end of a clean act, written by the provisioning script under the operator prefix with a digest over manifest and build; a take of act N starts from the state before it (section 8).
- **Labeled step**: a seeded, simulated or manual step named in the packet and excluded from acceptance (G6, D7); 13.3 lists them: seeded, simulated by the rehearsal script, manual.
- **Operator's machine** (B9): the laptop holding the keychain, the actors' profiles, the raw export and the packet; the demo's own boundary (7.3, TH15).
- **Packet**: the evidence delivered with the recording: pins, both definitions and digests, fixtures, receipts, record outcomes, admission reports and the rehearsal log (S07, R9).
- **Platform key, management key**: fAuth's credentials for creating tenants and for configuring one tenant, held only by the operator's shell (AS12, AR3).
- **Pre-take assertion**: the provisioning script's check of memberships, policies, fAuth's user list, row counts, a dry sign-in and the rate limit before every take (6.7, 11.1).
- **Provisioning script** (P9): the operator's idempotent script that creates the tenants, users, spaces, memberships, policies, the client row and role `reset` , and writes the fixture states (6.7).
- **Rehearsal script**: the take's driver on the operator's machine, over the Chrome DevTools Protocol: it brings one actor's profile forward at a time and makes 13.3's simulated faults at the client, a response held late, a response dropped after the server answered, the stale and reused-key requests; it adds no code to the product (D3; 11.1).
- **Rehearsal flag**: the environment variable in the demo's task definition under which alone the reset route registers, with role `reset` present; never set in the platform's deployment (6.7, 11.1, SI7).
- **Reset** (P11): the job that restores a named fixture state between takes under its own database role, keeping audit and sessions and bumping the membership epoch (6.7, 8, 9).
- **Spike**: the measurement before any scene: the path from definition to reopen on the real library and route, the commit's latency, the restart maximum, the route's bytes and its server render rate (R11, D8).
- **Synthetic label**: the organization row's `synthetic` flag the provisioning script sets and no member can, required on every organization before a reset (section 9).

- **Supervisor**: the process inside the container that restarts the binary in place, so a restart is a process restart, not a task replacement (5.2, 11.2).

B. References

The platform record's appendix B lists the shared sources: the controlling definition, the contracts, the pins of Forma 3.0.0 (`2006423b`) and fAuth (`b750ca53`), the earlier records, the standards and the vendor documentation. The demo's own, each cited at its point of use:

- `PRODUCT-BRIEF.md` (the demo's restatement of the controlling definition, whose sections are cited as §N: the six acts §16, the completeness test §18, the non-goals §19); `SCENARIOS.md` (S01 to S07, the fixtures and their arithmetic); `BUILD-HANDOFF.md` (the eight reductions and what is not a reduction); `platform-contract-lock.json` (edition `prep-2026-10-22.1`); `input/brief.md` ; `intake.md` (A1 to A10, the K rulings); `review/foundation-review.md` .
- The platform record, `tasks/forma-generative-app-platform-v2/design.md` , at the phase 7 commit this record cites, with its `review/fauth-viability.md` (fAuth at the pin, the handoff, the guards and the K4 ruling) and `review/spike-native-composition/` (the four-kind canvas at 27,674 of 28,100 B).
- Design B v5, the insurance demo this record revises in direction (tag `task/forma-mvp/v5` , folder `tasks/forma-insurance-demo`).
- Tickets on the Forma work board: FORMA-232 and FORMA-246 (assumed done, K3); FORMA-247 (fAuth as the demo's login: the redeploy at the pin, tenant provisioning, the client row, the rehearsal rate limit); FORMA-248 (fAuth's signing key in KMS).
- Vendor documentation, verified at the claims phase: AWS ECS on Fargate (task start and replacement, the public IPv4 charge per address), Application Load Balancer (the two-subnet minimum), RDS (single-instance snapshots inside the free allocation, IAM authentication's memory), S3 versioning, KMS key deletion (the 7-day minimum and the 24-hour hold the platform adds), Secrets Manager, the free 100 GB of egress; Chrome's sanitised HAR export and profiles; the Anthropic API's token pricing for the provider line.

C. Threat rows beyond section 10.4

The eight rows 10.4 does not keep, TH8 to TH15, on its scale and with its columns: the rows a platform control covers, re-rated for one process and one operator; every STRIDE category already has a row in 10.4. TH10 to TH12 are High on likelihood and Medium on impact because D1 and the platform's walls keep them inside one organization, TH10's escape half Low on likelihood and High on impact; TH14 is High on impact at Low likelihood; TH15 Medium and High; the rest Medium on both. The platform's rows map so: TH1 to the demo's TH4, TH3 to TH3, TH4 to TH10, TH7 to TH5, TH12 to TH9, TH13 to TH11, TH15 to TH12, TH16 to TH13; TH21 holds; the demo's TH8, TH14 and TH15 are new. Re-rated, with reasons: platform TH8, because platform M16's service token is not minted and a typed principal plus the callee's re-read of membership replace it, a control against a logic bug, not against code in the process, existing control none, Low/High, residual Medium (AR2); platform TH11, because the owner credential is a standing key in the operator's keychain with no breakglass and no outside reader, Medium/High, residual Medium (AR1, AR3), M31 making the audience the audit's reader; platform TH14, because the per-client edge limiter was a WAF rule and the WAF is reduced away while the host is public, so the in-process limits bound a signed-in member, not an outsider, High/Medium, residual Medium until M29's address allowlist at the load balancer is set (11.1), then Low; platform TH17 moot, synthetic rows and the snapshots deleted after delivery; platform TH27 removed with TA10. The head owns each residual risk.

ID	DFD element or boundary crossed	STRIDE	Threat statement	Invariant at stake	Existing control	Response	Mitigation	Likelihood	Impact	Status	Residual risk
TH8	B4, P11, P4, DS1, F7, F18	Tampering; Denial of service	The operator (TA9) resetting while a command is in flight, or double-clicking, can delete a record between a command's outcome lookup and its insert, which leads to an outcome without its record or a dead take's row surviving into the next, negatively impacting AS3	SI3, SI7	platform M40's locks [proposed]	mitigate	M15 prevent: the reset takes each organization's membership row `FOR UPDATE` in the transaction that deletes, serialising with every command's `FOR SHARE` (6.7); it is 409 while any job is claimed; it carries an `Idempotency-Key`; it bumps the epoch, so a command queued before it is denied at execution. M16 detect: the pre-take assertion counts rows against the state's manifest; a mismatch is a retake	Medium	Medium	proposed	Low
TH9	B1, DS4, P2, F4	Elevation of privilege	Jordan after Maya revokes his grant (TA3), or a cookie from a prior take, can keep calling for the session's remaining life, sessions surviving the reset, which leads to a read after revocation on camera or a prior take's principal acting in the next, negatively impacting AS1, AS3	SI4	platform M24 [proposed]	mitigate	M17 prevent: the epoch on every request (F4) with no cache before it, the canvas refresh at 5 s, and the reset's epoch bump, so every open tab re-authorizes within 5 s of a reset; a take of act 1 starts from a signed-out profile. M18 detect: the denial's time against the revocation's in the rehearsal log (N3's 5 s), in the packet	Medium	Medium	proposed	Low: a cookie of an unrevoked actor acts until sign-out
TH10	B6, P5, P6, P2	Denial of service; Elevation of privilege	A 4 MiB XLSX under A6's compressed cap, or any file a builder drops (TA3), inflating past 50 MiB in a WebAssembly module inside the one process can exhaust the host's memory, and a parser exploit escaping the module can run with every role's pool, both data keys and the provider key through the one task role, which leads to every role stopping, not one worker (D1), or to both organizations read and the operator's secrets taken, negatively impacting AS3, AS4, AS5, AS12	SI2, SI6	platform M8, M9 [proposed]	mitigate; accept the one process (AR2)	M19 prevent: the module's memory cap and fuel (A6) are enforced by the runtime below the task's 8 GiB (11.2), so the process survives the module; the byte caps refuse before parsing; the module has no system interface and no path to the task's credentials endpoint. M20 detect: the refusal and its reason captured (S06); a killed or crashed module audited; both parsers fuzzed in CI; a restart in a take is logged with the step redone (N2)	High (exhaustion); Low (escape)	Medium; High	proposed	Low; Medium: AR2

ID	DFD element or boundary crossed	STRIDE	Threat statement	Invariant at stake	Existing control	Response	Mitigation	Likelihood	Impact	Status	Residual risk
TH11	B5, P5, EE4	Tampering	S06's "export every secret" field (TA5), sent to the provider among the synthetic rows on camera, can steer the proposal, which leads to a misleading definition or an attempted operation outside D5's set, negatively impacting AS3	SI2	platform M26 [proposed]; the renderer admits no markup [built: review 4.3]	mitigate	M21 prevent: platform M26 unchanged, the field a delimited data value. M22 detect: the field runs as a test on every build, and the take's admission report, captured, shows the proposal validated whole with the field as data	High	Medium	proposed	Low: platform AR11
TH12	B3, P3, P5; platform F15	Tampering	The model (TA6), or the labeled fixture in the spike (TA11, a script bug), can propose an operation or kind outside D5's eleven, or the fixture can pass as generated, which leads to a draft rendering an unknown kind or a seeded proposal counted as working, negatively impacting AS2, AS10	SI2, SI8	the renderer refuses a computed kind [built: BUILD-610, review 4.3]; platform M30 [proposed]	mitigate	M23 prevent: platform M30 unchanged, admission failing whole, nothing partial stored; the fixture proposal carries a `fixture` label admission writes into its report, so P10 marks the scene seeded (G6). M24 detect: the admission report in the packet names the registry version and every refused kind	High	Medium	proposed	Low
TH13	B4, P4, DS1, F7, F8	Spoofing; Tampering	The canary's member (TA2) or Jordan (TA3) posting `ik-1` with Northstar's work id, or the next take reusing `ik-1`, can read another principal's outcome or receive a dead take's, which leads to a decision read across principals or a stale outcome answering a new take, negatively impacting AS3	SI3	none	mitigate	M25 prevent: platform M32's key (organization, principal, work, command, key), so the canary's post is 404 at P2 and Jordan's finds nothing; the reset deletes outcomes and flushes the cache, so a key crosses no take (section 9). M26 detect: key conflicts audited; the canary's and Jordan's `ik-1` in the packet	Medium	Medium	proposed	Low

ID	DFD element or boundary crossed	STRIDE	Threat statement	Invariant at stake	Existing control	Response	Mitigation	Likelihood	Impact	Status	Residual risk
TH14	B2 at the task definition, P2, P10, F13	Tampering; Repudiation	The operator (TA9) deploying a fix between acts 3 and 6 can change the build under the recording, which leads to N9's claim, one digest for both apps, failing unseen, negatively impacting AS10	SI8	none	mitigate	M27 prevent: one image digest for the whole recording; a new build is a new rehearsal (11.1). M28 detect: P10 reads the task's image digest at the take's start and end and the deploy log between them; a difference fails acceptance	Low	High	proposed	Low
TH15	B9, EE2, P9, P10, F12, F14 to F16	Information disclosure; Elevation of privilege	Whoever controls the operator's machine (TA1 by malware, a browser extension or theft; TA9) can take every key, every actor's session, the unfiltered export and the pin file at once, which leads to any principal in either organization and every operator power, negatively impacting AS1, AS11, AS12, AS13	SI1, SI8	the OS keychain prompt; full-disk encryption [built]	mitigate; accept the one machine (AR3)	M30 prevent: a fresh Chrome profile per actor with sync and extensions off, destroyed after the last take; the sanitised export plus P10's filter, the raw file hashed, filtered and deleted in one step; the platform key deleted from the keychain once the tenants exist; full-disk encryption; the machine off the network except while a rehearsal runs. M31 detect: the packet's manifest digest written as an audit event under the Object Lock anchor after each take, so an edited packet no longer matches; fAuth's user list and the session rows against the manifest before each take (M10); sign-out everywhere after each take	Medium	High	proposed	Low